arXiv:2611.11896v1 [cs.AI] 9 Nov 2026

LEGION: Benchmarking Language Agents on Sparse-Signal Investigation Under Adversarial Noise

Samuel Joseph Amouyal
Legion Security
samuel@legionsecurity.ai

Ofek Glick
Legion Security
ofek@legionsecurity.ai

Yaniv Menasherov
Legion Security
yaniv@legionsecurity.ai

Eyal Fisher
Legion Security
eyal@legionsecurity.ai

Ohav Barbi
Legion Security
ohav@legionsecurity.ai

Abstract

Autonomous language-model agents are increasingly deployed on discovery-driven tasks where signal is sparse and most retrieved information is irrelevant. Current benchmarks fail to evaluate this regime due to dense signals, cooperative environments, and ground truth typically being only a few tool calls away. We introduce LEGION, a benchmark framework coupling a stochastic enterprise-telemetry simulator (LEGION-SIM) with a tiered library of 74 expertly-crafted adversarial scenarios (LEGION-BENCH) and an evaluation protocol that scores investigation efficiency alongside detection accuracy. Scenarios are injected into freshly simulated companies, allowing independent control over confounder density and event volume. We test five agent architectures on two simulated companies and find that while recall is high (0.82-0.88) precision lags behind (0.61–0.72). They fail to find all of the indicators of compromise of the attack or mistake genuine indicators with attack related ones, which is critical in the context of cybersecurity investigation. Failures are consistent across reasoning tiers and persist across confounder density and event volume. We release LEGION, the scenario library, performance on common agent architectures, and pipeline for reproducibility and extension.

1 Introduction

Large language models [Team et al., 2024, Achiam et al., 2023, Qwen Team, 2026] are rapidly transitioning from passive question-answering systems into autonomous agents that act in the world [Qin et al., 2024, Patil et al., 2024]. They write code [Dong et al., 2025], navigate complex interfaces [Ning et al., 2025, Zheng et al., 2024], and orchestrate workflows across enterprise systems [Pelluru, 2025]. Agents are increasingly entrusted with decisions that carry real consequences: triaging medical records, flagging fraudulent transactions, and investigating security incidents [Hernandez Aros et al., 2024, Da'Costa et al., 2025]. As the autonomy granted to these agents grows, a precise account of what they *can* and *cannot* do becomes not merely useful, but necessary.

LLM agents are typically evaluated on tool use and environment interaction [Chen et al., 2021, Jimenez et al., 2023, Zhou et al., 2023, Yoran et al., 2024, Barbi et al., 2025]. These benchmarks share a structural property that quietly limits what they reveal: *the environment is informationally cooperative*. A failing test pinpoints the bug [Jimenez et al., 2023]; a web page surfaces the required elements [Zhou et al., 2023, Yao et al., 2022, Yoran et al., 2024]; an API call returns ground truth on demand [Xu et al., 2023]. Relevant signal is dense, retrievable, and rarely disguised.

This is not true in real investigations. Most observations are distractors, evidence is obscured, and no single query is decisive. Success requires **abductive reasoning**: forming hypotheses from

Preprint.

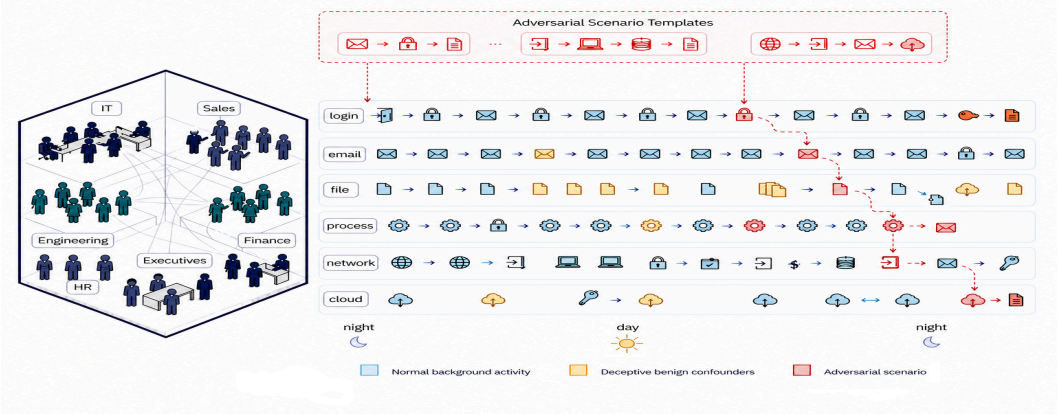

Figure 1: The LEGION-SIM pipeline. A stochastic enterprise environment generates event streams seeded with deceptive benign *confounders*. Adversarial scenario templates are then causally injected into this stream yielding realistic investigations in which signal is structurally indistinguishable from noise without contextual reasoning.

sparse evidence, designing queries to test them, and revising beliefs across interactions in which the overwhelming majority of retrieved information is noise. This an issue of *sustained inference under uncertainty*. The challenge is twofold: an agent must find the relevant evidence while also not being misled by the irrelevant. Confidently flagging spurious elements is as much a failure as missing true ones. When an agent makes 50 tool calls and produces a report full of spurious indicators, the failure rarely localizes to a single step: early missteps propagate silently, defining the search space for every query that follows. We call this *recursive discovery*, and existing benchmarks cannot isolate it because they fail to produce the conditions that trigger it: low signal-to-noise ratio, cross-source evidence fusion, and adversarial distractors that lead confident pattern-matching to wrong answers.

To this end, we introduce LEGION, a framework designed to isolate and evaluate recursive discovery in enterprise security operations. **LEGION-SIM** is a stochastic environment generator that produces enterprise environments with thousands of employees and hundreds of thousands of heterogeneous events. Crucially, it injects *deceptive benign activity*, confounders statistically indistinguishable from attack indicators without conditioning on each entity's role and baseline, so that naive pattern matching yields high false-positive rates and agents must reason over *distributional context* rather than surface signals. **LEGION-BENCH** is a tiered evaluation suite of 74 attack scenario templates built on top of LEGION-SIM, each specifying a causally ordered kill chain, ground-truth indicators of compromise, and expected investigative findings. Three tiers isolate distinct capabilities: *Tier 1* tests retrieval of a known indicator from a noisy observation space; *Tier 2* tests fusion of individually ambiguous signals across heterogeneous channels within an hour-scale window; *Tier 3* tests sustained hypotheses across multiple days of dwell time, following lateral connections without contextual drift.

We evaluate five agent architectures (Direct, ReAct, See–Plan–Act, Reflexion, and Multi-Agent) along *recall* and *precision*. Cybersecurity operations are an example of a domain in which both recall (retrieving all the attack event) and precision (distinguishing between genuine and malicious elements) are essential. While recall is high (0.82–0.88), precision lags behind (0.61–0.72). Additionally, they are both far from perfect which in the context of cybersecurity investigation can be specially dangerous. Interestingly the expected cliff between single-event detection and multi-day campaign reconstruction is gentler than expected.

These results highlight a central challenge for autonomous agents in discovery-driven domains: improving precision while preserving and further increasing recall. Agents recover much of the attack evidence, yet still miss relevant events and include spurious findings. Adaptive querying and more careful assessment of retrieved evidence are promising directions for addressing these gaps. We ground this challenge in cybersecurity, but similar demands may arise in other domains where agents must discover and evaluate evidence in noisy environments under a finite query budget.

2 Related Work

Agent benchmarks and the cooperative-environment assumption. The first generation of LLM-agent benchmarks established a now-standard template: a well-scoped task, an environment that exposes ground truth on request, and a verifiable terminal state. HumanEval Chen et al. [2021] and SWE-Bench Jimenez et al. [2023] score code generation against executable tests; WebArena Zhou et al. [2023], WebShop Yao et al. [2022], and Mind2Web Deng et al. [2023] score web navigation against deterministic DOM transitions; ToolBench Xu et al. [2023] and API-Bank Li et al. [2023] score API orchestration against schema-checked returns. Relevant elements are a few hops away and distractors are not adversarial. LEGION-SIM violates each of these assumptions by design.

Long-horizon and discovery-oriented evaluation. A second line of work targets long-horizon and partially observed environments. AssistantBench Yoran et al. [2024] and VeriWeb Liu et al. [2025] require persistent exploration across interdependent subtasks and report sharp degradation as horizon length grows. GAIA Mialon et al. [2023] couples multi-hop reasoning and tool use; BrowseComp Wei et al. [2025] stresses information-seeking under search-engine noise; AgentBench Liu et al. [2023] and OSWorld Xie et al. [2024] broaden the surface to OS interaction. These benchmarks treat horizon length and tool diversity as first-class variables, and several study how errors compound across steps. In LEGION-SIM, horizon length is not the central difficulty: every attack indicator has benign confounders statistically indistinguishable from it without conditioning on entity-specific baselines.

Abductive and hypothesis-driven reasoning. A separate thread evaluates the capacity to form, test, and revise hypotheses under incomplete information. AgentClinic Schmidgall et al. [2024] casts diagnosis as sequential evidence gathering; RULEARN He et al. [2025] probes interactive rule induction; DiscoveryWorld Jansen et al. [2024] embeds scientific-method loops in a simulated laboratory. These works share our emphasis on *abductive* rather than purely deductive reasoning, but their search spaces are typically small enough for a competent agent to enumerate hypotheses exhaustively. LEGION-SIM contains on the order of 10^5 heterogeneous events per scenario, and the cost of a wrong hypothesis is paid in query budget rather than a single penalized turn — which makes *recursive discovery* measurable.

Security operations as an evaluation domain. Cybersecurity has emerged as a natural testbed for agentic capabilities, as SOC work involves low signal-to-noise ratios and adversarial deception. ExCyTIn-Bench Wu et al. [2025] grounds agents in security telemetry and scores multi-hop evidence assembly; CTI-REALM Chakraborty et al. [2026] evaluates threat-intelligence synthesis across structured and unstructured sources; NYU CTF Shao et al. [2024] and Cybench Zhang et al. [2024] measure offensive capability via capture-the-flag tasks. Defensive benchmarks remain scarce, and most operate on real-world logs that are either small enough to admit memorization or so privacy-constrained that ground-truth attack labels are inferred. LEGION-SIM is, to our knowledge, the first generator that synthesizes enterprise telemetry with *causally injected* attack scenarios alongside benign confounders that are statistically engineered to defeat surface-level detection. This yields labeled ground truth at scale without sacrificing realism in the distribution of distractors.

3 The LEGION Testbed

Building a benchmark for discovery-driven reasoning requires placing the agent in conditions where abductive reasoning is not merely helpful but *structurally necessary*. We designed LEGION around three principles that jointly create this condition:

Ecological adversariality: the environment is not cooperative or indifferent, but actively deceptive. Adversarial activity is deliberately crafted to resemble normal behavior, ensuring that naive pattern matching yields a high false-positive rate.

Diagnostic isolability: *Legion* is stratified so that success at one tier paired with failure at the next yields a localized deficit signal, distinguishing whether an agent fails to find evidence, to filter noise, or to reconstruct a causal chain, rather than collapsing these into a single score.

Parametric control: every axis of difficulty, noise level, temporal span, evidence sources and adversarial sophistication is a tuneable parameter, enabling difficulty curves and scaling studies.

We instantiate these principles through two artifacts: LEGION-SIM, a stochastic environment generator that produces enterprise environments with hundreds of thousands of heterogeneous events (§3.1),

and LEGION-BENCH, a tiered evaluation suite that injects expertly-crafted adversarial scenarios of escalating complexity into that environment (§3.2). Although we ground LEGION in enterprise security operations, the capabilities it probes are domain-agnostic: any high-stakes setting that demands sustained reasoning under uncertainty will surface the same failure modes.

3.1 LEGION-SIM: A Stochastic Enterprise Environment

Existing agent benchmarks present curated tasks within bounded action spaces. Real investigations require the agent to *find* relevant leads in a massive, noisy observation space and folllow them. LEGION-SIM generates such an environment: a stochastically evolving world producing hundreds of thousands of structured interconnected events, of which only a tiny fraction are task-relevant.

Company model. Each company is specified by a YAML file defining an organizational graph: employees with role-conditioned parameters, departments, reporting hierarchies, devices, subnets, cloud infrastructure, mailboxes, and security groups. At runtime, we instantiate templates against this graph to produce ten event streams covering logins, emails, files, processes, applications, MFA, devices, prints, network flows, and administrative actions, plus three cloud streams for API calls, workload lifecycles, and threat-intelligence matches. All streams are materialized into a SQLite database tuned for the temporal, identity, and resource-access patterns of real SOC queries.

Employee-logs engine. Employees act according to role-conditioned distributions with circadian patterns, weekly cycles, and episodic bursts. Activity volumes follow tunable Zipf-like distributions. Each employee carries a stable profile (fixed IPs, known devices, preferred MFA, a Zipf-weighted application distribution) plus a small personalized noise term, forcing the agent to reason about *who* is acting, not just *what* occurred. Process events are drawn from four buckets: file-correlated, application-correlated, role-specific, and background OS processes, with realistic parent–child trees, log-normal lifetimes, and circadian scheduled-task profiles. The engine also generates correlated multi-actor events (email threads, cross-department collaborations, coordinated administrative actions), with participants selected by organizational proximity.

Email and file generation. Realistic content requires company-specific vocabulary, so we split generation into two phases. *Offline*, an LLM is prompted with the company YAML to produce (i) a catalog of email scenarios with participant roles, subjects, bodies, and timing offsets, and (ii) a file catalog with realistic paths, sensitivity labels, owner roles, and content descriptions (see Appendix A for the prompt). *Online*, the stochastic engine samples subjects and bodies from the templates, recipients from a department-biased distribution (60/30/10 same/adjacent/random), and attachments on 40% of messages from per-format size distributions. File events follow a session-based Markov chain with heavy-tailed sessions; action probabilities condition on the storage system (e.g. SharePoint biases toward reads), and shares spawn matching read tasks. Sensitivity labels propagate to the attack engine, which targets high-value files during exfiltration.

Network and cloud logs. Network flows cover internal east–west and external north–south traffic across twelve protocol templates (HTTPS, DNS, and others), each carrying direction, byte volumes, authentication method, and geolocation. Cloud logs are generated per instance and container at role-dependent rates, capturing service discovery, IAM changes, storage access, and workload management. Together, these streams ensure attack evidence can be distributed across all telemetry.

Deceptive benign activity. The engine deliberately produces benign events that resemble attack indicators, so naive pattern-matching yields high false-positive rates. We inject four *confounders* targeting common detection heuristics: late-night sessions, travel logins, bulk file operations, and failed-login clusters. Each generates fully correlated multi-field events — a travel login, for instance, combines unfamiliar geography, an unknown-device flag, and a plausible foreign IP, indistinguishable from account compromise without reasoning about the employee's context. Each is injected at a configurable rate, capped at three per employee per window. Full company configuration details in Appendix B; schemas and example records appear in Appendix C.

Family	#	T1	T2	T3	Representative templates
Social engineering / phishing	11	0	9	2	Manipulate a user into malicious actions
Account takeover / identity	14	3	6	5	Operate as a legitimate user via stolen credentials.
Endpoint / malware	13	0	9	4	Execute attacker code on a host to obtain persistent device control.
AD / hybrid identity	8	1	6	1	Abuse Kerberos and directory primitives to escalate privilege.
Cloud / SaaS	9	0	7	2	Misuse cloud IAM, APIs, or admin actions.
Data theft / exfil / DLP	10	0	4	6	Stage and egress sensitive data through monitored or covert channels.
Supply chain / DevOps	4	0	3	1	Poison build pipelines, container images, or CI/CD credentials.
Compound T3 campaigns	5	0	0	5	Multi-stage chains spanning two or more families.
Total	**74**	**4**	**44**	**26**	

Table 1: Threat-surface families in the LEGION-SIMattack catalog and their distribution across reasoning tiers. T1: minutes-scale. T2: hour-scale. T3: multi-day campaign with identity chaining.

3.2 LEGION-BENCH: A Tiered Reasoning Gauntlet

LEGION-BENCH is built around the insight that a correct verdict requires a structured reconstruction over several data sources. It provides 74 scenario templates, crafted by a security expert to reflect realistic adversarial behavior. Each template is a parameterized, causally ordered chain of heterogeneous events - emails, logins, process executions, file operations, network flows, and cloud audit records — paired with a kill-chain narrative, ground-truth indicators of compromise (IoCs), and expected investigative findings. Templates are organised along two orthogonal axes.

Threat-surface families. Templates are grouped into seven families that mirror how SOC teams triage incidents (Table 1). The grouping is descriptive rather than a partition; its purpose is to report family-level performance and ensure coverage across major intrusion patterns rather than concentrating on a single style of attack (e.g. phishing).

Reasoning tiers. Each template carries a tier label from {T1,T2,T3}, indicating the expected reasoning capability required to solve it (§3.2). Tiers are grounded in real-world dwell time: T1 scenarios are minutes-scale, single-action attacks with a direct indicator; T2 scenarios are hour-scale, single-session multi-phase chains whose individual events are ambiguous in isolation; T3 scenarios are multi-day campaigns with persistent state and identity chaining.

At test time, templates are instantiated against a concrete LEGION-SIM company: victim identity, attacker infrastructure, and timing offsets are sampled per instance, yielding fresh ground truth for every run. Injection respects the infrastructure graph: an action targeting resource m_j may only follow once the adversary holds credentials for m_j, and compromised entities continue their normal stochastic behavior between adversarial events, burying signal in noise. Attack events carry structured metadata (attack phase, victim identity, indicator flags) used exclusively by the evaluator and never exposed to the agent. See Appendix D for the full templates descriptions.

Alert format. Each scenario instance has an *alert* block as the agent's sole input. The information disclosed within the alert is minimal, removing the possibility of solving the task without investigation.

```
### Description
Defender for Office 365 flagged suspicious inbound email activity targeting
maverick.cox@meridianhcp.com  at 2026-04-03T16:49:38Z. The message matched heuristic
detection rules. Investigate the full scope of the activity, identify indicators of
compromise, and determine the impact.
### Initial Indicators
  - email: maverick.cox@meridianhcp.com
```

4 Experimental Setup and Evaluation

We evaluate a range of LLM agents on LEGION-BENCH to answer three main questions: (1) Can agents reliably reconstruct a attack chains without surfacing spurious evidence? (2) Does investigation quality degrade as complexity increases? (3) Do the results vary across agent architectures?

Tier	ER	FR	IoC R.	IoC P.
T1	0.97 / 0.95	1.0 / 1.0	0.76 / 0.80	0.56 / 0.59
T2	0.97 / 0.97	0.97 / 0.96	0.86 / 0.86	0.70 / 0.72
T3	0.82 / 0.86	0.86 / 0.91	0.89 / 0.92	0.60 / 0.68

Table 2: Per-tier performance averaged across all five agents. Format: MERIDIAN / NEXUSTECH.

Variant	ER	FR	IoC R.	IoC P.
Baseline	0.91	0.92	0.88	0.69
3× confounders	0.90	0.92	0.87	0.67
3× events	0.89	0.92	0.86	0.65

Table 3: Effect of scaling confounders and event volume on MERIDIAN, ReAct only.

4.1 Tested Architectures

Agents share a common infrastructure: they receive an alert with initial indicators, interact with the environment through the SOC tool interface (see Appendix E for a full tool description) and produce a structured investigation report. They differ in the *strategy* imposed during the investigation loop.

In the **Direct** architecture, the agent freely alternates between reasoning and tool calls until it produces a report. **ReAct** Yao et al. [2023] adds structure by constraining the agent to a strict *Thought–Action–Observation* loop, externalizing reasoning before every tool call. **SPA (See–Plan–Act)** Yoran et al. [2024] enforces an alternation between a *planning* phase and an *execution* phase, with a `request_replan` action allowing the agent to revise its plan mid-investigation. **Reflexion** Shinn et al. [2023] performs two passes: after the first, a critic LLM prompted as a senior SOC analyst identifies gaps in the draft report, and the agent addresses them. Finally, **Multi-Agent** mirrors SOC team structure: a coordinator triages the alert and assigns tasks to domain specialists (endpoint, identity, email, data, threat intelligence, cloud), each with only the tools matching their domain, before synthesizing all findings into a unified report. See Appendix F for all our agents' prompts.

Golden Workflow. We compare our agents to a deterministic baseline that executes a fixed sequence of SOC tool calls derived from expert-authored playbooks (see Appendix G for details). A *single* LLM call synthesises the collected evidence into a report. Alerts are routed to one of four typed workflows (AccountTakeover, Phishing, Malware, DLP) based on the alert source field. The Golden Workflow serves as an interpretable reference point for assessing whether adaptive LLM reasoning adds measurable investigative value over deterministic automation.

4.2 Evaluation Metrics

We evaluate agent performance along two complementary axes: *the report* and *the investigation*. This separation is essential, as a good report without finding all the attack events might miss the mark.

Reporting quality We look at the Indicators of Compromise (IoC) surfaced in the report and measure **IoC Recall and Precision**. Each scenario specifies ground-truth IoCs grouped by category: IP addresses, domains, URLs, and email addresses. We evaluate IoC presence in the agent's report via string matching. Additionally, we measure **Findings Recall (FR).** Each scenario defines a set of *expected findings*: specific conclusions a competent investigator should reach. We check whether the agent's *Findings* section contains each one using an LLM-as-judge Zheng et al. [2023] and FR is the fraction of expected findings marked found. We validate our judge by manually inspecting 100 of the judgments and were in agreement with the judge in 98% of the cases (see Appendix F for details).

Investigative coverage Each scenario carries attack events with full signatures. We can derive from there **Event Recall (ER)**: the fraction of attack events surfaced during the investigation. Unlike FR, ER scores the trajectory, not the write-up.

5 Results

We evaluate all five agents, using GPT-5.5 (OpenAI [2026]) and a budget of up to 20 LLM calls, on the full LEGION-BENCH corpus, instantiated against MERIDIAN, a healthcare company with 300+ employees and 600k events. We additionally run half the scenarios against NEXUSTECH, a company with 2M+ events. Each template is instantiated five times per company, with results averaged.

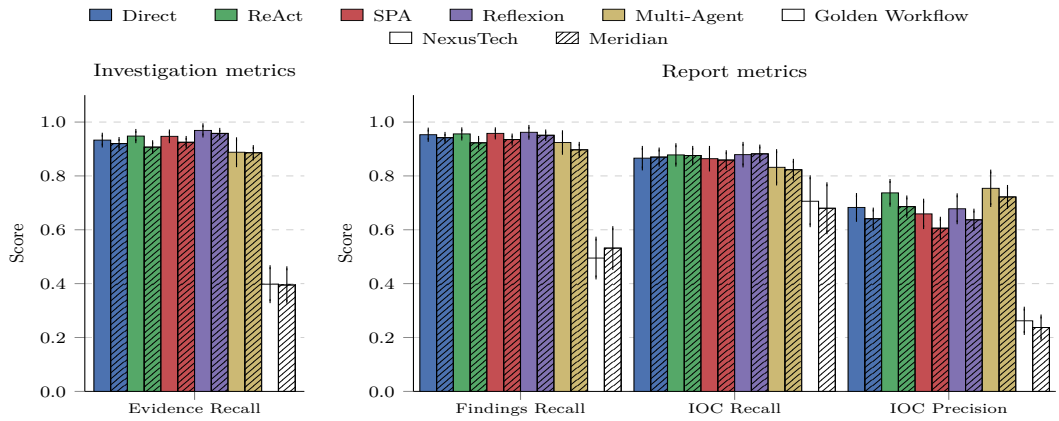

Figure 2: Investigation metrics and report metrics for each agent on NEXUSTECH (solid) and MERIDIAN (hatched). Error bars are 95% confidence intervals over scenarios.

	Direct				ReAct				Multi-Agent			
Model	**ER**	**FR**	**IoC R**	**IoC P**	**ER**	**FR**	**IoC R**	**IoC P**	**ER**	**FR**	**IoC R**	**IoC P**
GPT-5.6 Terra	0.83	0.89	0.79	0.75	0.82	0.90	0.79	0.72	0.75	0.85	1.00	0.67
GPT-5.6 Luna	0.88	0.91	0.80	0.52	0.82	0.90	0.80	0.44	0.81	0.85	0.99	0.47
Gemini Pro	0.78	0.82	0.75	0.71	0.76	0.84	0.82	0.65	0.64	0.37	0.94	0.85
Claude Opus 4.7	0.75	0.89	0.82	0.56	0.75	0.87	0.85	0.61	0.71	0.91	0.99	0.40

Table 4: Agent performance on MERIDIAN across backbone models. ER: Evidence Recall; FR: Findings Recall; IoC R / IoC P: IoC recall / precision. Runs that errored are excluded.

5.1 Neither recall nor precision are saturated

Frontier agents reach relative high recall and precision but never saturate. Figure 2 compares report metrics (Findings Recall, IoC Precision and Recall) with investigation coverage (Event Recall) across all five architectures and both companies. Findings Recall (0.91–0.96), Event Recall (0.89–0.97), and IoC Recall (0.82–0.88) and Precision (0.61–0.72) are high but do not saturate—a critical limitation in cybersecurity, where identifying *all* attack-related events and IoCs is essential.

5.2 Per-tier behavior: the cliff is gentler than expected.

Table 2 stratifies performance by reasoning tier. The expected recall cliff between cross-source correlation (T2) and multi-day campaigns (T3) is present but **shallower than expected**: 5–10 points of Findings Recall and 11–15 points of Event Recall separate T2 from T3, across agents. Interestingly, Tool-Call Accuracy rises with tier far less than event budget would suggest: T3 contains up to 3$\times$ more attack events than T1, yet TCA is essentially flat.

5.3 Ablations.

Fixed playbooks In both recall metrics and indicator F1 scores, LLM agents significantly outperform golden workflows. This shows that our benchmark is challenging, and that rule-following automations are not sufficient.

Additional confonders The headline results in §5 use the baseline LEGION-SIM parameters, raising a natural concern: would the apparent saturation on report-side metrics dissolve under heavier noise or larger event volumes? To test this, we re-instantiate MERIDIAN along two perturbation axes with attack scenarios and agents held fixed: `confounders_3x` triples the rate of benign red-herring activity, and `events_3x` triples the per-employee event budget. Table 3 shows the results of each variant and compared to baseline ReAct runs. Overall, it does not significantly change the results, meaning that adding noise does not influence the model's performance.

	Direct				ReAct			
Toolset	**ER**	**FR**	**IoC R**	**IoC P**	**ER**	**FR**	**IoC R**	**IoC P**
Full toolset (baseline)	0.92	0.94	0.87	0.64	0.91	0.92	0.88	0.69
No analysis tools	0.92	0.92	0.84	0.69	0.88	0.90	0.82	0.72
Query-only	0.85	0.86	0.81	0.66	0.84	0.89	0.83	0.70

Table 5: Tool ablations on MERIDIAN (GPT-5.5).

Additional models While we did not run the full setup (5 agents, with 5 victims for each scenario) due to the prohibitive cost, we did run Gemini-3.1-Pro, Opus-4.7, GPT-5.6-Luna and GPT-5.6-Terra on all the scenarios with 3 agents (React, Direct and SPA) with one victim for all the scenarios. In Table 4 we can see that all these models do not saturate neither on recall nor on precision. Additionally, while recall is relatively similar across models, precision changes a lot, and strong models are essential to properly identify IoCs.

Tool ablations To verify the impact of the tools provided on the investigation, we run two additional ablations. In the first, the model still received tools but we removed tools that conduct some detection logic (get risky users, detect suspicious processes, etc) that can be considered as being some oracle calls. Additionally, in threat intelligence, we reduce the information given to "Malicious/Benign" without noting which attacks the entity participated in. In the second, the agent is given only the ability to run SQL queries on the company database and the threat intelligence tool. In Table 5 we can see that the available tools do not influence the results too much, just the Evidence Recall a bit.

6 Analysis

To further demonstrate how LEGION-SIM and LEGION-BENCH can be used, we conduct additional analyses of our results by looking at where the agents break. Two classes stand out, each diagnostic of a distinct reasoning weakness.

Slow drip exploitation Several T3 scenarios reveal a common failure mode: without a sharp anomaly, agents often miss the full scope of adversarial activity. This is most evident in BEC invoice diversion (38–75% FR, 37–76% ER), where legitimate-looking emails are spread over weeks, and also appears in malicious browser extensions (49% ER, 68% FR) and consent phishing with slow exfiltration (44% ER, 61% FR). In these cases, agents detect the initial suspicious event but fail to trace delayed downstream activity across channels.

Insider theft using legitimate credentials. Mass-download-on-resignation (FR 52–72%, ER 50–66%) and source-code-repo theft (FR 57–83%, ER 56–83%) remain challenging across architectures. Here, all actions use valid credentials and legitimate access, so detection depends on identifying behavioral anomalies; such as unusual volume, out-of-scope repositories, or off-hours activity; rather than any single malicious event. Agents do not reliably perform this broader statistical reasoning.

7 Conclusion

We introduced LEGION, a benchmark framework pairing a stochastic enterprise simulator with a tiered attack scenario library and an evaluation protocol scoring both detection accuracy and investigation efficiency. Findings and Event Recall sit between 0.82–0.95, but precision remains low (0.61–0.72) across all agents, with many elements spuriously flagged. The binding constraint for current agents is not finding the right evidence, but doing so without surfacing noise, and current architectures, including those designed to plan and reflect, do not solve it. At this level of precision, autonomous deployment in real investigative settings would be difficult. While these problems were surfaced from a cybersecurity environment, we believe these conclusions would generalize to any task which requires abductive reasoning within a noisy environment. We release LEGION, LEGION-BENCH, the agents, and the pipeline so the community can extend and contest these findings. [1]

[1] Code and data: `https://github.com/legion-security/legion-bench`

Limitations

While we aimed to make our simulation as realistic as possible, we believe that short of taking actual logs from a company (which would face anonymization considerations) it is near impossible to provide a 1 to 1 simulation of an actual company. However, we still argue our simulation is useful enough to surface interesting conclusions. Additionally, due to the high cost of running these agents in this environment, we did not scale the number of companies nor the base LLMs tested. Finally, while the results plainly show agents fail at this task in ways that differ from humans, a larger human comparison is required. This type of comparison is lengthy, still underway and will provide additional insights into the performance of LLM based agent with respect to humans. Alongside the defensive improvements possible through this environment, we must also consider the risk posed. In theory, attackers can use the environment to craft and simulate attacks on companies, measuring AI agent performance and optimizing their attacks to evade agentic investigations. While this is a consideration, we believe the option to pinpoint agentic faults and improve them outweighs this risk.

References

Josh Achiam, Steven Adler, Sandhini Agarwal, Lama Ahmad, Ilge Akkaya, Florencia Leoni Aleman, Diogo Almeida, Janko Altenschmidt, Sam Altman, Shyamal Anadkat, et al. Gpt-4 technical report. *arXiv preprint arXiv:2303.08774*, 2023.

Ohav Barbi, Ori Yoran, and Mor Geva. Preventing rogue agents improves multi-agent collaboration. In Ehsan Kamalloo, Nicolas Gontier, Xing Han Lu, Nouha Dziri, Shikhar Murty, and Alexandre Lacoste, editors, *Proceedings of the 1st Workshop for Research on Agent Language Models (REALM 2025)*, pages 486–511, Vienna, Austria, July 2025. Association for Computational Linguistics. ISBN 979-8-89176-264-0. URL https://aclanthology.org/2025.realm-1.34/.

Arjun Chakraborty, Sandra Ho, Adam Cook, and Manuel Meléndez. Cti-realm: Benchmark to evaluate agent performance on security detection rule generation capabilities. *arXiv preprint arXiv:2603.13517*, 2026.

Mark Chen, Jerry Tworek, Heewoo Jun, Qiming Yuan, Henrique Ponde De Oliveira Pinto, Jared Kaplan, Harri Edwards, Yuri Burda, Nicholas Joseph, Greg Brockman, et al. Evaluating large language models trained on code. *arXiv preprint arXiv:2107.03374*, 2021.

Adebayo Da'Costa, Jennifer Teke, Joseph E Origbo, Ayokunle Osonuga, Eghosasere Egbon, and David B Olawade. Ai-driven triage in emergency departments: A review of benefits, challenges, and future directions. *International Journal of Medical Informatics*, 197:105838, 2025.

Xiang Deng, Yu Gu, Boyuan Zheng, Shijie Chen, Sam Stevens, Boshi Wang, Huan Sun, and Yu Su. Mind2web: Towards a generalist agent for the web. *Advances in Neural Information Processing Systems*, 36:28091–28114, 2023.

Yihong Dong, Xue Jiang, Jiaru Qian, Tian Wang, Kechi Zhang, Zhi Jin, and Ge Li. A survey on code generation with llm-based agents. *arXiv preprint arXiv:2508.00083*, 2025.

Kaiyu He, Mian Zhang, Shuo Yan, Peilin Wu, and Zhiyu Chen. Idea: Enhancing the rule learning ability of large language model agent through induction, deduction, and abduction. In *Findings of the Association for Computational Linguistics: ACL 2025*, pages 13563–13597, 2025.

Ludivia Hernandez Aros, Luisa Ximena Bustamante Molano, Fernando Gutierrez-Portela, John Johver Moreno Hernandez, and Mario Samuel Rodríguez Barrero. Financial fraud detection through the application of machine learning techniques: a literature review. *Humanities and Social Sciences Communications*, 11(1):1–22, 2024.

Peter Jansen, Marc-Alexandre Côté, Tushar Khot, Erin Bransom, Bhavana Dalvi Mishra, Bodhisattwa Prasad Majumder, Oyvind Tafjord, and Peter Clark. Discoveryworld: A virtual environment for developing and evaluating automated scientific discovery agents. *Advances in Neural Information Processing Systems*, 37:10088–10116, 2024.

Carlos E Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. Swe-bench: Can language models resolve real-world github issues? *arXiv preprint arXiv:2310.06770*, 2023.

Minghao Li, Yingxiu Zhao, Bowen Yu, Feifan Song, Hangyu Li, Haiyang Yu, Zhoujun Li, Fei Huang, and Yongbin Li. Api-bank: A comprehensive benchmark for tool-augmented llms. In *Proceedings of the 2023 conference on empirical methods in natural language processing*, pages 3102–3116, 2023.

Shunyu Liu, Minghao Liu, Huichi Zhou, Zhenyu Cui, Yang Zhou, Yuhao Zhou, Jialiang Gao, Heng Zhou, Yunhao Yang, Wendong Fan, et al. Veriweb: Verifiable long-chain web benchmark for agentic information-seeking. *arXiv preprint arXiv:2508.04026*, 2025.

Xiao Liu, Hao Yu, Hanchen Zhang, Yifan Xu, Xuanyu Lei, Hanyu Lai, Yu Gu, Hangliang Ding, Kaiwen Men, Kejuan Yang, et al. Agentbench: Evaluating llms as agents. *arXiv preprint arXiv:2308.03688*, 2023.

Grégoire Mialon, Clémentine Fourrier, Thomas Wolf, Yann LeCun, and Thomas Scialom. Gaia: a benchmark for general ai assistants. In *The Twelfth International Conference on Learning Representations*, 2023.

Liangbo Ning, Ziran Liang, Zhuohang Jiang, Haohao Qu, Yujuan Ding, Wenqi Fan, Xiao-yong Wei, Shanru Lin, Hui Liu, Philip S Yu, et al. A survey of webagents: Towards next-generation ai agents for web automation with large foundation models. In *Proceedings of the 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining V. 2*, pages 6140–6150, 2025.

OpenAI. Gpt-5.5 (chatgpt). `https://chat.openai.com/`, 2026. Large language model.

Shishir G Patil, Tianjun Zhang, Xin Wang, and Joseph E Gonzalez. Gorilla: Large language model connected with massive apis. *Advances in Neural Information Processing Systems*, 37, 2024.

Karthik Pelluru. Langchain & langgraph in production: Architectures for multi-agent llm systems. *Journal of Data and Digital Innovation (JDDI)*, 2(3):1–9, 2025.

Yujia Qin, Shihao Liang, Yining Ye, Kunlun Zhu, Lan Yan, Yaxi Lu, Yankai Lin, Xin Cong, Xiangru Tang, Bill Qian, et al. Toolllm: Facilitating large language models to master 16000+ real-world apis, 2023. *URL https://arxiv. org/abs/2307.16789*, 2, 2024.

Qwen Team. Qwen3.5: Towards native multimodal agents, February 2026. URL `https://qwen.ai/blog?id=qwen3.5`.

Samuel Schmidgall, Rojin Ziaei, Carl Harris, Eduardo Reis, Jeffrey Jopling, and Michael Moor. Agentclinic: a multimodal agent benchmark to evaluate ai in simulated clinical environments, 2024.

Minghao Shao, Sofija Jancheska, Meet Udeshi, Brendan Dolan-Gavitt, Haoran Xi, Kimberly Milner, Boyuan Chen, Max Yin, Siddharth Garg, Prashanth Krishnamurthy, et al. Nyu ctf bench: A scalable open-source benchmark dataset for evaluating llms in offensive security. *Advances in Neural Information Processing Systems*, 37:57472–57498, 2024.

Noah Shinn, Federico Cassano, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. Reflexion: Language agents with verbal reinforcement learning. *Advances in neural information processing systems*, 36:8634–8652, 2023.

Gemini Team, Petko Georgiev, Ving Ian Lei, Ryan Burnell, Libin Bai, Anmol Gulati, Garrett Tanzer, Damien Vincent, Zhufeng Pan, Shibo Wang, et al. Gemini 1.5: Unlocking multimodal understanding across millions of tokens of context. *arXiv preprint arXiv:2403.05530*, 2024.

Jason Wei, Zhiqing Sun, Spencer Papay, Scott McKinney, Jeffrey Han, Isa Fulford, Hyung Won Chung, Alex Tachard Passos, William Fedus, and Amelia Glaese. Browsecomp: A simple yet challenging benchmark for browsing agents. *arXiv preprint arXiv:2504.12516*, 2025.

Yiran Wu, Mauricio Velazco, Andrew Zhao, Manuel Raúl Meléndez Luján, Srisuma Movva, Yogesh K Roy, Quang Nguyen, Roberto Rodriguez, Qingyun Wu, Michael Albada, et al. Excytin-bench: Evaluating llm agents on cyber threat investigation. *arXiv preprint arXiv:2507.14201*, 2025.

Tianbao Xie, Danyang Zhang, Jixuan Chen, Xiaochuan Li, Siheng Zhao, Ruisheng Cao, Toh J Hua, Zhoujun Cheng, Dongchan Shin, Fangyu Lei, et al. Osworld: Benchmarking multimodal agents for open-ended tasks in real computer environments. *Advances in Neural Information Processing Systems*, 37:52040–52094, 2024.

Qiantong Xu, Fenglu Hong, Bo Li, Changran Hu, Zhengyu Chen, and Jian Zhang. On the tool manipulation capability of open-source large language models, 2023.

Shunyu Yao, Howard Chen, John Yang, and Karthik Narasimhan. Webshop: Towards scalable real-world web interaction with grounded language agents. *Advances in Neural Information Processing Systems*, 35:20744–20757, 2022.

Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing reasoning and acting in language models. In *International Conference on Learning Representations (ICLR)*, 2023.

Ori Yoran, Samuel Joseph Amouyal, Chaitanya Malaviya, Ben Bogin, Ofir Press, and Jonathan Berant. Assistantbench: Can web agents solve realistic and time-consuming tasks? In *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing*, pages 8938–8968, 2024.

Andy K Zhang, Neil Perry, Riya Dulepet, Joey Ji, Celeste Menders, Justin W Lin, Eliot Jones, Gashon Hussein, Samantha Liu, Donovan Jasper, et al. Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. *arXiv preprint arXiv:2408.08926*, 2024.

Boyuan Zheng, Boyu Gou, Jihyung Kil, Huan Sun, and Yu Su. Gpt-4v (ision) is a generalist web agent, if grounded. *arXiv preprint arXiv:2401.01614*, 2024.

Lianmin Zheng, Wei-Lin Chiang, Ying Sheng, Siyuan Zhuang, Zhanghao Wu, Yonghao Zhuang, Zi Lin, Zhuohan Li, Dacheng Li, Eric Xing, et al. Judging llm-as-a-judge with mt-bench and chatbot arena. *Advances in neural information processing systems*, 36:46595–46623, 2023.

Shuyan Zhou, Frank F Xu, Hao Zhu, Xuhui Zhou, Robert Lo, Abishek Sridhar, Xianyi Cheng, Tianyue Ou, Yonatan Bisk, Daniel Fried, et al. Webarena: A realistic web environment for building autonomous agents. *arXiv preprint arXiv:2307.13854*, 2023.

A Company Generation Prompts

The offline preparation pass (§3.1) calls an LLM (Claude Sonnet via LiteLLM) four times per company to generate email scenarios and a file catalog. All calls share a common preamble; specialised prompts extend it with task-specific directives. Dynamic fields derived from the company YAML are shown in `<angle brackets>`.

Shared Preamble (injected into every generation call)

```
You are generating email scenario templates for a company simulation system.

## Company Profile
- Name: <company_name>
- Domain: <domain>
- Description: <description>
- Size: <N> employees
- Locations: <location_list>

## Departments and Roles
- <Dept A> (<pct>% of employees): Role1, Role2, ...
- <Dept B> (<pct>% of employees): Role1, Role2, ...
[...]

## Template Slot System
<slot documentation: {sender}, {recipient_1}, {date}, etc.>
```

```
## Key Requirements
1. Multi-participant conversations: 2-4 participants
2. Realistic timing: use offset_hours for response times
3. Natural conversation flow
4. Professional tone specific to this industry
5. Industry-specific language and terminology
6. Output: JSON array matching this schema (one object per scenario):

[
  {
    "id": "<company_id>_<unique_slug>",
    "name": "Human-readable scenario name",
    "description": "Brief description of the conversation",
    "num_participants": 2,                    // integer, 2-6
    "participant_roles": ["initiator", "responder"],  // drives slot aliases
    "same_department": true,                  // false for cross-dept scenarios
    "departments": ["<dept_name>"],           // lock to specific departments
    "requires_manager": false,               // true if one participant = manager
    "cross_department": false,               // true if participants from diff depts
    "requires_file": false,                  // true if a file attachment is needed
    "file_types": ["pdf", "docx"],           // allowed attachment extensions
    "num_external": 0,                       // external (non-company) participants
    "urgency": "normal",                     // "normal" | "high" | "critical"
    "weight": 1.0,                           // selection weight
    "tags": ["collaboration", "review"],
    "emails": [
      {
        "offset_hours": 0.0,          // float: hours after scenario start
        "sender_index": 0,            // index into participant list (0=initiator)
        "subject_template": "Review needed: {file_name}",
        "body_template": "Hi {participant_1_name}, ...",
        "recipient_indices": [],      // empty = all other participants
        "include_attachment": false,
        "reply_to_previous": false,   // prepends "Re: " to original subject
        "cc_indices": []              // participant indices to CC
      }
    ]
  }
]

Template slots available in subject_template and body_template:
  {participant_N_name}, {participant_N_email}  -- N-th participant (0-indexed)
  {<role>_name}, {<role>_email}                -- alias from participant_roles
  {file_name}, {file_description}, {file_type} -- attachment context
  {company_name}, {company_domain}, {department}
  {project_name}, {deadline}, {quarter}, {date_reference}
  {meeting_day}, {meeting_time}
```

Email Scenarios — Per-Department

```
<shared preamble>

## Department: <dept_name>
Roles in this department: <role_list>

Generate 5 unique email scenarios specifically for the <dept_name>
department at <company_name>.

Each scenario should:
1. Feel authentic to someone in <dept_name> at a company like <company_name>
2. Involve 2-4 participants with realistic roles from this department
3. Have 3-5 emails showing natural conversation progression
4. Include at least one scenario with a file attachment
5. Vary in urgency (mostly normal, one or two high priority)
```

```
6. Use industry-specific terminology
7. Set "departments": ["<dept_name>"] for each scenario
8. Prefix each id with "<company_id>_"

Output only valid JSON, no additional text or explanation.
```

Additional calls produce 8 cross-department scenarios (participants from 2–3 departments), 6 urgent scenarios (`urgency: "high"` or `"critical"`, short response offsets, subject-line urgency markers), and 10 generic scenarios covering the remaining variety.

File Catalog — Per-Department

```
You are generating file metadata for a company simulation system.

## Company: <company_name>
<description>

## Department: <dept_name>
Roles: <dept> - Role1, <dept> - Role2, ...

## Task
Generate exactly <N> file entries for the <dept_name> department.

Requirements:
1. Realistic documents that people in <dept_name> at <company_name> would use
2. owner role format: "Department - Role" using exact names above
3. Paths start with /departments/<dept_slug>/
4. Realistic extensions: .pdf, .docx, .xlsx, .pptx, .csv, .md
5. Subdirectories for organisation (e.g. .../Reports/, .../Projects/)
6. Sensitivity mix: ~45% business, ~30% regular, ~15% confidential,
   ~10% unlabeled
7. Dates between 2022-01-01 and 2025-03-31
8. Content: 1-2 sentence description of what the file contains
9. Industry-specific and realistic for <company_name>

Output only valid JSON array, no additional text or explanation.
```

A separate call generates shared company-wide files under `/shared/` (policies, HR documents, brand materials, compliance guides) using the same schema, with `owner role` drawn from any department.

B Company Configuration Schema

Each simulated company is specified as a YAML configuration file. The file drives the static generation pass and controls every structural aspect of the company: headcount, organizational graph, group memberships, network topology, application inventory, and behavioral baselines. Below we show an abbreviated but representative excerpt from the MERIDIAN HEALTHCARE PARTNERS configuration, one of the two companies used throughout our experiments. Fields that accept long lists (first-name pools, role-manager chains, full application catalogs) are truncated with `[...]` for space.

```yaml
# ——— Overall workforce parameters ————————————————————————————————
overall:
  employees: 300
  department_distribution:
    Clinical Operations: 0.30
    Nursing:             0.15
    Administration:      0.10
    IT:                  0.05
    Finance & Billing:   0.08
    HR:                  0.05
    Compliance & Risk:   0.04
```

```
    Pharmacy:            0.04
    Laboratory:          0.05
    Radiology:           0.03
    Patient Services:    0.03
    Executive:           0.03
    Facilities:          0.05
  role_distribution:            # per-department title weights
    Clinical Operations:
      Chief Medical Officer:  0.01
      Medical Director:       0.03
      Attending Physician:    0.20
      Resident:               0.15
      Nurse Practitioner:     0.12
      Physician Assistant:    0.10
      Medical Assistant:      0.20
      Clinical Coordinator:   0.05
      Surgeon:                0.04
      Hospitalist:            0.05
      Clinical Informaticist: 0.05
    Nursing:
      Chief Nursing Officer:        0.02
      Nursing Director:             0.05
      Nurse Manager:                0.10
      Charge Nurse:                 0.10
      Registered Nurse:             0.35
      Licensed Practical Nurse:     0.20
      Certified Nursing Assistant:  0.13
      Nurse Educator:               0.05
    # [... 11 additional departments omitted ...]
  role_managers:                # reporting-chain specification
    Clinical Operations:
      Chief Medical Officer:  CEO
      Medical Director:       Chief Medical Officer
      Attending Physician:    Medical Director
      Resident:               Attending Physician
      Nurse Practitioner:     Medical Director
      # [...]

# ——— Company identity ———————————————————————————————————————————————————————————————————————————————
company:
  id:     meridian_healthcare
  name:   Meridian Healthcare Partners
  domain: meridianhcp.com
  description: >
    Regional healthcare network operating hospitals, outpatient clinics,
    and specialty care centers in the northeastern United States. HIPAA-
    regulated, uses EHR systems extensively, and employs physicians,
    nurses, and allied health professionals alongside administrative
    and IT staff.
  locations:
    - US-BOS-HQ
    - US-HFD
    - US-PVD

# ——— Groups (security boundaries + authorisation sets) ——————————————
groups:
  - id:   grp_physicians
    name: Physicians Group
    member_roles:
      - Clinical Operations - Attending Physician
      - Clinical Operations - Surgeon
      - Clinical Operations - Hospitalist
      - Clinical Operations - Medical Director
    authorisations:
      - Epic EHR - admin
```

```
      - Cerner - admin
      - Dragon Medical - operator
      - Imprivata - operator
      - Microsoft Teams - operator

  - id:   grp_it_admins
    name: IT Administrators
    member_roles:
      - IT - Chief Information Officer
      - IT - IT Director
      - IT - IT Manager
      - IT - Systems Administrator
    authorisations:
      - Okta - admin
      - Active Directory - admin
      - CrowdStrike - admin
      - Imprivata - admin
      - Microsoft 365 - admin
      - Epic EHR - admin

  - id:   grp_compliance_team
    name: Compliance and Risk Team
    member_roles:
      - Compliance & Risk - Chief Compliance Officer
      - Compliance & Risk - Compliance Director
      - Compliance & Risk - Privacy Officer
      - Compliance & Risk - Internal Auditor
    authorisations:
      - Compliancy Group - admin
      - Healthicity - admin
      - Epic EHR - reader
      - SharePoint - operator
      - DocuSign - operator
  # [... 13 additional groups omitted ...]

# ─── Network topology ──────────────────────────────────────────────────────────
networks:
  - {id: net_bos_hq, cidr: 10.0.0.0/16, location: US-BOS-HQ,
     name: meridian-hq-boston}
  - {id: net_hfd,    cidr: 10.1.0.0/16, location: US-HFD,
     name: meridian-hartford}
  - {id: net_pvd,    cidr: 10.2.0.0/16, location: US-PVD,
     name: meridian-providence}

# ─── Device fleet ──────────────────────────────────────────────────────────────
devices:
  count: 350
  network_distribution:
    net_bos_hq: 0.50
    net_hfd:    0.25
    net_pvd:    0.25

# ─── Mailboxes ─────────────────────────────────────────────────────────────────
mailboxes:
  distribution_lists:
    - {address: physicians@meridianhcp.com,
       members_from_group: grp_physicians,       delegate_count: 3}
    - {address: nursing@meridianhcp.com,
       members_from_department: Nursing,         delegate_count: 4}
    - {address: compliance@meridianhcp.com,
       members_from_group: grp_compliance_team,  delegate_count: 2}
    - {address: it@meridianhcp.com,
       members_from_department: IT,              delegate_count: 3}
    - {address: exec@meridianhcp.com,
       members_from_group: grp_c_suite,          delegate_count: 1}
```

```
    # [...]

# ─── Application inventory ──────────────────────────────────────────────────────────────────────
applications:
  internal:
    - {name: Patient Portal,        type: patient_engagement, criticality: critical}
    - {name: Clinical Dashboard,    type: analytics,          criticality: critical}
    - {name: Lab Information System,type: laboratory,         criticality: high}
    - {name: Staff Intranet,        type: knowledge_base,     criticality: medium}
  external:   # SSO-integrated applications (28 total)
    - {name: Epic EHR,          type: ehr,                  sso: true}
    - {name: Cerner,            type: ehr,                  sso: true}
    - {name: MEDITECH,          type: ehr,                  sso: true}
    - {name: Microsoft 365,     type: productivity,         sso: true}
    - {name: Microsoft Teams,   type: communication,        sso: true}
    - {name: Okta,              type: idp,                  sso: true}
    - {name: CrowdStrike,       type: edr,                  sso: true}
    - {name: Imprivata,         type: clinical_sso,         sso: true}
    - {name: SharePoint,        type: file_storage,         sso: true}
    - {name: Workday,           type: hris,                 sso: true}
    - {name: Philips IntelliSpace, type: medical_imaging,   sso: true}
    - {name: Compliancy Group,  type: compliance,           sso: true}
    - {name: QGenda,            type: scheduling,           sso: true}
    - {name: Citrix,            type: virtual_desktop,      sso: true}
    # [...]

# ─── Temporal model and weekly activity weights ─────────────────────────────────
generation_config:
  location_timezones:
    US-BOS-HQ: -5.0
    US-HFD:    -5.0
    US-PVD:    -5.0
  temporal:
    window_days: 30
    circadian:
      concentration: 2.5      # von Mises concentration for intra-day bursts
    weekly_weights:            # Mon-Sun relative activity multipliers
      default:    [1.0, 1.0, 1.0, 1.0, 1.0, 0.15, 0.10]
      clinical:   [1.0, 1.0, 1.0, 1.0, 1.0, 0.70, 0.60]
      nursing:    [1.0, 1.0, 1.0, 1.0, 1.0, 0.80, 0.75]
      laboratory: [1.0, 1.0, 1.0, 1.0, 1.0, 0.50, 0.40]
      radiology:  [1.0, 1.0, 1.0, 1.0, 1.0, 0.40, 0.30]
      pharmacy:   [1.0, 1.0, 1.0, 1.0, 1.0, 0.50, 0.40]
      executive:  [1.0, 1.0, 1.0, 1.0, 1.0, 0.20, 0.08]
      it:         [1.0, 1.0, 1.0, 1.0, 1.0, 0.20, 0.10]

# ─── Episodic bursts ──────────────────────────────────────────────────────────────────────────────
  bursts:
    enabled: true
    types:
      - name: patient_surge
        probability: 0.03
        duration_days:        { mean: 5,  std: 2 }
        intensity_multiplier: { mean: 2.0, std: 0.4 }
        affected_event_types: [logins, app_events, email_events]
        department_bias: [Clinical Operations, Nursing]
      - name: regulatory_audit
        probability: 0.02
        duration_days:        { mean: 10, std: 3 }
        intensity_multiplier: { mean: 1.8, std: 0.3 }
        affected_event_types: [file_events, email_events, app_events]
        department_bias: [Compliance & Risk, Administration]
      - name: quarter_end
        probability: 0.04
        duration_days:        { mean: 5,  std: 1 }
```

```
        intensity_multiplier: { mean: 1.8, std: 0.3 }
        affected_event_types: [email_events, file_events, app_events]
        department_bias: [Finance & Billing, Administration]

# ——— Confounder injection ——————————————————————————————————————————————————————
  confounders:
    enabled: true
    types:
      - name: late_night_work
        rate: 0.10
        eligible_roles: ["*Director*", "*VP*", "*Chief*",
                         "*Senior*", "*Manager*", "*Attending*", "*Surgeon*"]
        effect:
          duration_events: { mean: 3, std: 1 }

      - name: travel_login
        rate: 0.04
        eligible_roles: ["*VP*", "*Director*", "*Chief*",
                         "*Executive*", "*Sales*"]
        effect:
          duration_events:           { mean: 2, std: 1 }
          unknown_device_probability: 0.5

      - name: bulk_file_operation
        rate: 0.05
        eligible_roles: ["*Billing*", "*Compliance*", "*HR*",
                         "*Manager*", "*Director*", "*Health Information*"]
        effect:
          file_count_multiplier: { mean: 4.0, std: 1.5 }

      - name: failed_login_cluster
        rate: 0.06
        eligible_roles: ["*"]
        effect:
          failure_count:      { mean: 4, std: 2 }
          followed_by_success: true

# ——— Per-role behavioral baselines (role_policies) ——————————————————————
# Each role carries 9 baseline channels. Four representative roles
# shown below - the full config defines baselines for all 60 titles.

role_policies:
  # ---------- Attending Physician ----------
  # Clinical shift: early morning, midday, and evening login windows.
  # Low VPN usage (mostly on-premises workstations). EHR and Dragon
  # Medical-heavy process profile. Normal admin action rate near zero.
  "Clinical Operations - Attending Physician":
    baselines:
      login_baseline:
        vpn_pct: { mean: 0.10, std: 0.04 }
        hours:   ["06:00-08:00", "11:00-13:00", "14:00-16:00", "18:00-20:00"]
        isps:    ["Comcast", "Charter", "AT&T"]
        avg_events_per_day: { mean: 3.0, std: 1.0 }
      email_baseline:
        avg_inbound_per_day:    { mean: 55,  std: 15 }
        avg_events_per_day:     { mean: 6.0, std: 2.0 }
        typical_attachments:    ["pdf", "docx", "xlsx", "jpg"]
      process_baseline:         ["chrome", "epic", "dragon", "outlook",
                                 "teams", "imprivata", "citrix"]
      process_event_baseline:
        avg_events_per_day:     { mean: 6.0, std: 2.0 }
      net_baseline:             ["epic.meridianhcp.com",
                                 "mail.meridianhcp.com",
                                 "uptodate.com",
                                 "pubmed.ncbi.nlm.nih.gov"]
```

```
    file_baseline:
      avg_events_per_day:     { mean: 9.0,  std: 3.0 }
    network_baseline:
      avg_events_per_day:     { mean: 9.0,  std: 3.0 }
    device_baseline:
      avg_events_per_day:     { mean: 2.0,  std: 0.7 }
    app_baseline:
      avg_events_per_day:     { mean: 10.0, std: 3.0 }
    admin_baseline:
      avg_events_per_day:     { mean: 0.03, std: 0.02 }

# ---------- Registered Nurse ----------
# Three-shift rotation (07:00, 15:00, 23:00 shift starts).
# Almost exclusively on-site; VPN pct \approx 3%. Simpler process set
# dominated by Epic, Vocera, and Imprivata (badge SSO).
"Nursing - Registered Nurse":
  baselines:
    login_baseline:
      vpn_pct: { mean: 0.03, std: 0.02 }
      hours:   ["06:00-07:00", "14:00-15:00", "22:00-23:00"]
      isps:    ["Comcast", "Charter", "AT&T"]
      avg_events_per_day: { mean: 3.0, std: 1.0 }
    email_baseline:
      avg_inbound_per_day:    { mean: 25,  std: 8  }
      avg_events_per_day:     { mean: 6.0, std: 2.0 }
      typical_attachments:    ["pdf", "docx"]
    process_baseline:         ["epic", "vocera", "outlook",
                               "imprivata", "chrome"]
    process_event_baseline:
      avg_events_per_day:     { mean: 6.0, std: 2.0 }
    net_baseline:             ["epic.meridianhcp.com",
                               "mail.meridianhcp.com",
                               "meridianhcp.com"]
    file_baseline:
      avg_events_per_day:     { mean: 9.0, std: 3.0 }
    network_baseline:
      avg_events_per_day:     { mean: 9.0, std: 3.0 }
    device_baseline:
      avg_events_per_day:     { mean: 2.0, std: 0.7 }
    app_baseline:
      avg_events_per_day:     { mean: 10.0, std: 3.0 }
    admin_baseline:
      avg_events_per_day:     { mean: 0.03, std: 0.02 }

# ---------- IT Systems Administrator ----------
# Elevated VPN usage (38%), broad hours, and high process event
# rate reflecting scripting and admin tooling. Network event rate
# 2× the clinical baseline. Meaningful admin action rate (0.5/day).
"IT - Systems Administrator":
  baselines:
    login_baseline:
      vpn_pct: { mean: 0.38, std: 0.10 }
      hours:   ["07:00-10:00", "12:00-16:00", "18:00-22:00"]
      isps:    ["Comcast", "Charter", "AT&T", "Verizon Fios"]
      avg_events_per_day: { mean: 8.0, std: 3.0 }
    email_baseline:
      avg_inbound_per_day:    { mean: 50,  std: 12 }
      avg_events_per_day:     { mean: 7.0, std: 2.0 }
      typical_attachments:    ["pdf", "xlsx", "ps1", "sh", "log"]
    process_baseline:         ["chrome", "powershell", "terminal",
                               "okta", "activedirectory",
                               "imprivata", "citrix"]
    process_event_baseline:
      avg_events_per_day:     { mean: 14.0, std: 4.0 }
    net_baseline:             ["okta.meridianhcp.com",
```

```
                              "ad.meridianhcp.com",
                              "teams.microsoft.com",
                              "meridianhcp.com"]
    file_baseline:
      avg_events_per_day:     { mean: 9.0,  std: 3.0 }
    network_baseline:
      avg_events_per_day:     { mean: 18.0, std: 6.0 }
    device_baseline:
      avg_events_per_day:     { mean: 4.0,  std: 1.2 }
    app_baseline:
      avg_events_per_day:     { mean: 15.0, std: 5.0 }
    admin_baseline:
      avg_events_per_day:     { mean: 0.5,  std: 0.2 }

# ---------- Compliance Analyst ----------
# Standard office hours, moderate VPN (15%). Compliance tooling
# (Compliancy Group, Healthicity) and heavy file access - this role
# is eligible for the bulk_file_operation confounder, so benign
# clustered file reads can resemble an exfiltration pattern.
"Compliance & Risk - Compliance Analyst":
  baselines:
    login_baseline:
      vpn_pct: { mean: 0.15, std: 0.06 }
      hours:   ["08:00-10:00", "12:00-14:00", "15:00-17:00"]
      isps:    ["Comcast", "Charter", "AT&T"]
      avg_events_per_day: { mean: 3.0, std: 1.0 }
    email_baseline:
      avg_inbound_per_day:    { mean: 40,  std: 10 }
      avg_events_per_day:     { mean: 6.0, std: 2.0 }
      typical_attachments:    ["pdf", "xlsx", "csv", "docx"]
    process_baseline:         ["chrome", "outlook", "teams",
                               "compliancy-group", "healthicity", "excel"]
    process_event_baseline:
      avg_events_per_day:     { mean: 6.0, std: 2.0 }
    net_baseline:             ["mail.meridianhcp.com",
                               "teams.microsoft.com",
                               "sharepoint.com",
                               "meridianhcp.com"]
    file_baseline:
      avg_events_per_day:     { mean: 9.0, std: 3.0 }
    network_baseline:
      avg_events_per_day:     { mean: 9.0, std: 3.0 }
    device_baseline:
      avg_events_per_day:     { mean: 2.0, std: 0.7 }
    app_baseline:
      avg_events_per_day:     { mean: 10.0, std: 3.0 }
    admin_baseline:
      avg_events_per_day:     { mean: 0.03, std: 0.02 }
# [... 56 additional role policies omitted ...]
```

The full configuration for MERIDIAN HEALTHCARE PARTNERS spans approximately 2 800 lines covering 13 departments, 60 role titles, 16 groups, 3 office networks, 28 external applications, and complete `role_policies` baselines for every role title. The four roles shown above illustrate the principal axes of behavioral variation: VPN usage (3%–40%), login hour distributions (three-shift clinical vs. standard office hours), process event rates (6–14 events/day), network activity rates (9–18 events/day), and admin action rates (0.03–0.5 events/day). These per-role baselines, combined with a small per-employee noise term sampled at generation time, are what force the agent to reason about *who* is acting rather than merely *what* action occurred.

C Event Log Schemas and Examples

The simulator produces ten distinct event types, each stored in its own table in the SQLite twin database. Below we show one or two representative rows per type drawn from the NEXUSTECH

GLOBAL baseline fixture. Attack-injected events carry an additional `_attack_metadata` field that is stripped before SQL insertion and used only for ground-truth evaluation.

Authentication Events (`logins`)

```
{
  "ts":           "2026-03-27T00:25:53Z",
  "ip":           "39.161.90.94",
  "method":       "SSO+MFA",          // SSO | Password | Password+MFA
                                      // | SessionToken | MFA-only
  "success":      true,
  "app":          "DocuSign",
  "geo":          "VPN-US",
  "user_agent":   "Mozilla/5.0 (Windows NT 10.0; Win64; x64)
                   AppleWebKit/537.36 Chrome/124.0.0.0 Safari/537.36",
  "device_id":    "dev_00000",
  "known_device": true
}
// Attacker session replay (injected event):
{
  "ts":           "2026-03-27T01:42:10Z",
  "ip":           "185.234.72.143",
  "method":       "SessionToken",
  "success":      true,
  "app":          "Microsoft 365",
  "geo":          "Eastern Europe",
  "device_id":    "unknown",
  "known_device": false,
  "user_agent":   "python-requests/2.28.0"
}
```

Email Events (`email_events`)

```
{
  "ts":               "2026-04-13T11:38:00Z",
  "direction":        "sent",          // sent | received
  "external":         false,
  "from":             "greta.long@meridianhcp.com",
  "to":               ["avery.ramos@meridianhcp.com"],
  "cc":               [],
  "bcc":              [],
  "subject":          "Sharing: executive_team_meeting_october2024.docx",
  "content":          "Hi Avery, sharing the October exec meeting minutes ...",
  "attachment_types": ["docx"],
  "attachments": [{
    "filename":  "executive_team_meeting_october2024.docx",
    "url":       "https://mail.meridianhcp.com/attachments/937641fdde84",
    "file_path": "/departments/executive/Meeting_Minutes/
                  executive_team_meeting_october2024.docx",
    "size_bytes": 162956
  }]
}
// Phishing lure (injected):
{
  "ts":           "2026-04-13T09:15:22Z",
  "direction":    "received",
  "external":     true,
  "from":         "security@login-secure-m365.com",
  "subject":      "Action Required: Verify Your Identity to Continue",
  "content":      "We detected suspicious activity on your account ...",
  "contains_url": "https://login-secure-m365.com/view/42891"
}
```

File Events (`file_events`)

```
{
  "ts":          "2026-03-27T01:11:11Z",
  "action":      "read",            // read | modify | upload | delete | copy
  "path":        "\\\\docrepo\\Clinical Operations\\Reports\\
                  or_utilization_analysis_aug2024.pdf",
  "system":      "document_repository",
  "label":       "Business",        // DLP sensitivity label
  "owner_role": "Clinical Operations - Surgeon",
  "category":    "business",
  "description":"OR utilization report: surgical volume trends and
                 capacity optimization."
}
{
  "ts":          "2026-03-27T12:11:35Z",
  "action":      "modify",
  "path":        "https://meridianhealthcarepartners.sharepoint.com/
                 sites/Clinical Operations/Shared Documents/Reports/
                 quality_metrics_dashboard_q4_2024.xlsx",
  "system":      "microsoft_sharepoint",
  "label":       "Business",
  "owner_role": "Clinical Operations - Chief Medical Officer",
  "category":    "business",
  "description":"Quality metrics dashboard: patient safety indicators,
                 readmission rates, and clinical outcomes Q4 2024."
}
```

Process Events (`process_events`)

```
{
  "ts":              "2026-03-29T14:08:52Z",
  "process_name":    "chrome.exe",
  "action":          "start",      // start | stop | crash | inject
  "parent_process":  "explorer.exe",
  "path":            "C:\\Program Files\\Google\\Chrome\\Application\\
                      chrome.exe",
  "pid":             24041,
  "integrity_level": "medium",
  "command_line":    "\"C:\\Program Files\\Google\\Chrome\\Application\\
                      chrome.exe\"",
  "hash":            "098f63fb41e1d75261742ba2044fe043617d3fcb1fd157b9...",
  "user_context":    "MERIDIAN\\greta.long",
  "device_id":       "dev_00300"
}
// Malicious process (injected):
{
  "ts":              "2026-03-29T14:42:17Z",
  "process_name":    "IT_Support_Tool.exe",
  "action":          "start",
  "parent_process":  "OUTLOOK.EXE",
  "path":            "C:\\Users\\Public\\Downloads\\IT_Support_Tool.exe",
  "integrity_level": "high",
  "command_line":    "IT_Support_Tool.exe --silent --install",
  "hash":            "e7b1c9d2a4f83b...",
  "user_context":    "MERIDIAN\\hans.ortiz",
  "device_id":       "dev_00142"
}
```

Application Events (`app_events`)

```
{
  "ts":            "2026-03-27T12:09:57Z",
  "app":           "SharePoint",
```

```
  "action":        "export_data",  // access | login | export_data
                                   // | create_inbox_rule | search_mailbox
                                   // | open_url | navigate | ...
  "usage":         "read",
  "success":       true,
  "resource_type": "export",
  "resource_name": "Q4 Quality Metrics Report",
  "description":   "Exported SharePoint record to local download"
}
// Attacker action (injected):
{
  "ts":            "2026-03-27T23:14:03Z",
  "app":           "Outlook Web Access",
  "action":        "create_inbox_rule",
  "resource_name": "Auto-Delete Security Alerts",
  "description":   "Inbox rule to auto-delete emails containing
                    'security alert' or 'unusual sign-in'"
}
```

MFA Events (`mfa_events`)

```
{
  "ts":          "2026-03-30T17:23:59Z",
  "action":      "push_sent",   // push_sent | push_approved | push_denied
                                // | totp_success | totp_failure
                                // | device_registered | device_removed
  "method":      "push",
  "device_name": "Okta Verify",
  "app":         "Okta",
  "ip":          "72.33.80.49"
}
{
  "ts":          "2026-03-30T17:24:06Z",
  "action":      "push_approved",
  "method":      "push",
  "device_name": "Okta Verify",
  "app":         "Okta",
  "ip":          "72.33.80.49",
  "success":     true
}
```

Device Events (`device_events`)

```
{
  "ts":          "2026-03-27T00:09:14Z",
  "action":      "bluetooth_connect",  // bluetooth_connect | usb_insert
                                       // | usb_remove | device_enrolled
                                       // | device_wiped | screen_lock
  "device_type": "bluetooth_speaker",
  "vendor":      "JBL",
  "product":     "Clip 4",
  "device_id":   "dev_00000"
}
// USB exfiltration (injected):
{
  "ts":          "2026-03-27T18:33:41Z",
  "action":      "usb_insert",
  "device_type": "usb_storage",
  "vendor":      "SanDisk",
  "product":     "Ultra USB 3.0",
  "serial":      "48291037"
}
```

Administrative Actions (`admin_actions`)

```
{
  "ts":          "2026-04-04T01:22:07Z",
  "system":      "okta",           // okta | azure_ad | active_directory
                                   // | aws_iam | endpoint_mgmt | ...
  "action":      "add_to_group",   // add_to_group | remove_from_group
                                   // | enable_mfa | register_mfa_device
                                   // | assign_role | create_service_principal
  "approved_by": "self",
  "details": {
    "group_id":   "grp_radiology_team",
    "group_name": "Radiology Team"
  }
}
// Persistence action (injected):
{
  "ts":            "2026-04-04T02:11:55Z",
  "system":        "okta",
  "action":        "register_mfa_device",
  "approved_by":   "self",
  "resource_name": "Microsoft Authenticator",
  "description":   "New Authenticator app registered from attacker session"
}
```

Network Events (`network_events`)

```
{
  "ts":               "2026-03-27T00:03:18Z",
  "source_ip":        "10.10.0.244",
  "destination_ip":   "9.220.215.99",
  "destination_port": 80,
  "protocol":         "TCP",
  "action":           "allowed",   // allowed | blocked | detected
  "direction":        "outbound",
  "user":             "hao.gomez",
  "auth":             "none",
  "bytes_sent":       9903,
  "bytes_received":   9253,
  "description":      "HTTP web browsing"
}
// C2 beacon (injected):
{
  "ts":               "2026-03-29T22:04:51Z",
  "source_ip":        "185.234.72.143",
  "destination_ip":   "52.96.0.40",
  "destination_port": 443,
  "user":             "hans.ortiz",
  "bytes_sent":       524288,
  "bytes_received":   2097152,
  "description":      "Sustained HTTPS session to M365 from foreign IP -
                       mailbox and portal access"
}
```

Print Events (`print_events`)

```
{
  "ts":            "2026-04-02T09:14:33Z",
  "document_name": "Patient_Discharge_Summary_Batch_April.pdf",
  "printer":       "HP-LaserJet-NursingStation-3W",
  "pages":         24,
  "copies":        1,
  "label":         "Confidential",
  "app":           "Epic EHR"
```

}

D Attack Catalog

LEGION-BENCH ships 74 adversarial scenario templates spanning seven threat-surface families. Each template is parameterised (attacker domains, IPs, lure subjects, C2 infrastructure) and injected independently per scenario instance, so no two runs share the same concrete IOCs. The full catalog is listed below, grouped by reasoning tier.

Tier 1 — Single-indicator, pattern-matching difficulty (4 scenarios)

New MFA Device Registration for Persistence. After compromise, attacker enrolls a new MFA method to maintain access even after a password reset and browses the victim's mailbox for sensitive content.

Silent Mailbox Forwarding Rule. Attacker logs in from a foreign IP, creates a silent forwarding rule to exfiltrate all incoming email to an external address.

Inbox Hiding Rules for Alert Suppression. Attacker creates inbox rules to suppress security-alert and finance-related emails and hide traces of the compromise.

LSASS Memory Dump for Credential Extraction. Attacker dumps LSASS memory to extract NTLM hashes and Kerberos tickets for subsequent lateral movement.

Tier 2 — Cross-source correlation, multi-step within a single session (44 scenarios)

AiTM Phishing — Session Token Theft via Reverse Proxy. Reverse-proxy between victim and real login captures session cookie; attacker replays stolen session, registers MFA device, creates inbox rules, and sets up mail forwarding.

Device Code Phishing — OAuth Token Hijack. Attacker initiates Device Code OAuth flow and sends code to victim; victim unwittingly grants persistent token access; attacker browses portal, dumps mailbox, and registers MFA device.

OAuth Consent Phishing — Malicious App Authorization. Victim authorises a malicious OAuth app with delegated Graph API permissions; app reads mailbox, accesses OneDrive, and adds a client secret for persistence.

Email Thread Hijacking — Trusted Reply Lure. Attacker hijacks a legitimate email thread from a compromised peer's mailbox to lure a second victim into credential submission.

Cloud Document Share Notification Lure. Fake OneDrive sharing notification redirects victim to credential phishing page; attacker logs in from foreign IP and exfiltrates SharePoint files.

Password Spraying — Low-and-Slow Credential Attack. Common passwords are tried across many accounts to avoid lockouts; successful login is followed by mailbox browsing and contact export.

Privileged Role Assignment to Compromised Account. Attacker with compromised admin credentials assigns Global Administrator role and creates a service principal for persistent elevated access.

ISO/LNK Attachment Payload Chain. Malware delivered via ISO disk image and LNK shortcut; payload beacons to C2, performs host discovery, and stages data for exfiltration.

DLL Sideloading via Legitimate Application Bundle. Phishing email delivers ZIP with a legitimate signed app and malicious DLL; sideloaded DLL establishes C2 and sets persistence via scheduled task.

Legitimate Remote Access Tool Installation. Attacker installs AnyDesk or similar RAT for persistent interactive access that blends with normal IT usage, then harvests credentials and exfiltrates data.

Browser and Windows Credential Store Stealer. Infostealer fingerprints the host, harvests credentials from browsers and DPAPI, compresses loot into an encrypted archive, and exfiltrates to C2.

EDR / Security Tooling Disabling and Tampering. Attacker enumerates security tools, disables EDR and Windows Defender, clears event logs, deploys payload, and maintains C2.

Protocol Tunneling for Covert C2 Channel. Encrypted reverse tunnel (chisel) over HTTPS blends C2 with web traffic; attacker performs host discovery, credential harvesting, and exfiltration through the tunnel.

Kerberoasting — Service Ticket Offline Cracking. Attacker requests Kerberos TGS tickets for SPN-bearing accounts and cracks them offline to recover service account credentials.

Pass-the-Hash NTLM Lateral Movement. Stolen NTLM hash is injected to authenticate across multiple hosts via SMB without cleartext password; data collected on final target.

DCSync — Directory Replication Credential Extraction. Attacker uses DRSUAPI replication rights to extract domain admin, krbtgt, and service account hashes.

Golden Ticket — Forged Kerberos TGT. Using stolen KRBTGT hash, attacker forges TGTs to impersonate any domain identity and access high-value services.

Local Admin Credential Reuse — Mass Lateral Movement. Shared local admin hash reused across many machines via SMB pass-the-hash with discovery commands at each hop.

Cloud Service Discovery / Enumeration. After gaining cloud access, attacker performs a broad resource sweep across subscriptions, storage, IAM, databases, and containers.

Cloud Admin Run-Command Abuse. Attacker uses AWS Systems Manager RunCommand to execute recon and exfiltration on production VMs without SSH/RDP access.

Object Storage Mass Download. Attacker enumerates S3 buckets, checks ACLs, and downloads large volumes of data using built-in sync tools.

Cloud Secret Vault / Key Manager Theft. Attacker enumerates key vaults and reads high-value secrets (database passwords, API keys, certificates).

IAM Role / Policy Tampering for Privilege Escalation. Attacker modifies IAM policy to add wildcard permissions and attaches them to their own identity for unrestricted access.

Cloud Logging / Audit Trail Suppression. Attacker disables CloudTrail, log sinks, and monitoring alerts before exfiltrating data under reduced visibility.

SaaS Platform Bulk Data Export. Attacker with compromised admin credentials initiates multiple export jobs (mailbox, SharePoint, Teams) and transfers them externally.

Collaboration Platform Lure / Internal Phishing. Compromised account scouts the org via Teams/Slack and sends targeted lures to harvest a second set of credentials.

Source Code Repository Theft. Developer credentials used to enumerate and clone multiple private repositories, scan for embedded secrets, and exfiltrate build artifacts.

Poisoned CI/CD Pipeline via Malicious PR. Attacker PR injects malicious workflow that dumps CI secrets, tampers with artifact integrity, and publishes a backdoored artifact.

CI/CD Token Theft for Multi-System Access. Malicious CI job dumps environment variables with cloud credentials, accesses Secrets Manager, and exfiltrates to attacker-controlled endpoint.

Malicious Container Image Swap. Attacker pushes a malicious image overwriting a legitimate container tag; Kubernetes pulls it; attacker executes commands and steals service account tokens.

DocuSign Credential Harvesting. Phishing email impersonating DocuSign redirects victim to fake login; attacker replays credentials from foreign IP, browses mailbox, and exfiltrates SharePoint documents.

Microsoft 365 Credential Harvesting. Attacker impersonates M365 security alert to steal credentials; uses them to browse portal, read mailbox, and download OneDrive files.

IT Support Impersonation Malware Delivery. Attacker impersonates IT support to convince victim to run malware disguised as a security update; malware establishes C2 and exfiltrates data.

Voicemail Notification MFA Capture. Fake voicemail HTML attachment presents an MFA capture page; stolen session replayed from foreign IP with subsequent inbox rule creation.

Vendor Invoice QR Code Redirect. Fake vendor invoice PDF contains QR code leading to a credential harvesting page; stolen credentials used to access mailbox.

Credential Stuffing with Impossible Travel. Breach-leaked credentials tested in rounds with cooldown; successful Evilginx session replay from geographically impossible location.

MFA Fatigue Push Bombing Attack. Dozens of MFA push notifications exhaust user into accidentally approving one; attacker logs in, registers device, creates inbox rule.

Session Hijacking via Token Theft. Malware extracts browser session tokens; attacker replays sessions without credentials or MFA to access mailbox and SharePoint.

Help Desk Social Engineering. Attacker impersonates victim to the help desk, convinces IT staff to reset MFA, then enrolls attacker-controlled device.

LOLBins Living-off-the-Land Attack. Attack chain using legitimate Windows binaries (Excel macro $\rightarrow$ PowerShell $\rightarrow$ certutil $\rightarrow$ mshta) to evade detection.

Ransomware Deployment Attack. Multi-stage attack starting with RDP brute force; Cobalt Strike beacon, LSASS dump, EDR disabling, VSS deletion, then ransomware deployment across hosts.

Fileless Malware PowerShell Attack. Teams/Slack link delivers JavaScript loader; PowerShell executes entirely in memory, harvests browser credentials, and exfiltrates via DNS tunneling.

Personal Email Data Exfiltration. Employee systematically exports sensitive reports and SharePoint files and emails them to a personal Gmail account before deleting sent items.

Screenshot and Print Exfiltration. Employee captures screenshots from sensitive applications, prints confidential documents, and copies all data to a personal phone via USB.

Tier 3 — Multi-day campaign reconstruction, long-horizon reasoning (26 scenarios)

BEC Invoice Diversion — Payment Redirection Fraud. Attacker compromises a finance-adjacent account, intercepts a legitimate invoice thread, and redirects a wire transfer to an attacker-controlled account across multiple email exchanges.

MFA and Conditional Access Policy Weakening. Attacker with admin access progressively loosens conditional access policies to exempt compromised accounts from MFA requirements before exfiltrating data.

Service Principal and App Secret Persistence. Attacker creates service principals with client secrets tied to compromised identities, establishing durable machine-to-machine access that survives password resets.

Guest User Invitation Abuse for Persistence. Attacker invites attacker-controlled guest accounts with elevated permissions, using legitimate B2B collaboration features to maintain long-term access.

Federation Trust and SAML Configuration Modification. Attacker with hybrid identity admin rights modifies SAML federation trust to allow forged assertions, enabling persistent authentication bypass.

Scheduled Task and Registry Run Key Persistence. PowerShell-delivered payload creates scheduled task and Registry Run key for persistence; re-executes multiple times across days while collecting and exfiltrating data.

DNS Tunneling for Covert C2 and Data Exfiltration. Implant encodes data in DNS TXT queries across multiple days, maintaining a low-volume covert channel that evades volumetric detection.

Malicious Browser Extension for Session and Credential Theft. Attacker deploys a malicious browser extension that silently harvests session tokens and credentials across multiple web applications over days.

Group Policy Object Abuse for Mass Payload Deployment. Attacker modifies GPO to deploy a malicious scheduled task across all hosts in a target OU; multiple machines execute the payload after policy refresh.

AD CS Certificate Abuse (ESC1 / SAN Forgery). Misconfigured certificate template exploited to request a certificate impersonating a Domain Admin; used for persistent Kerberos authentication across multiple systems over days.

Cloud API Key Creation for Persistence. Attacker creates multiple long-lived API keys across cloud services, establishing persistent access that survives IAM policy changes.

Cloud Infrastructure Cryptomining Abuse. Attacker provisions high-compute instances across multiple regions for cryptomining, gradually scaling usage to avoid cost-anomaly alerts.

Mailbox Collection via Platform Export. Attacker with compliance admin credentials creates eDiscovery searches, exports PST files, and exfiltrates them over HTTPS.

Archive-Based Staging and Exfiltration. Attacker collects files in small batches over multiple days, stages into password-encrypted archives disguised as system backups, and exfiltrates in sized chunks.

DNS Tunneling Exfiltration. Implant encodes sensitive data in DNS TXT queries across multiple days to stay below volume detection thresholds.

Double Extortion: Data Theft then Ransomware. Over multiple days, attacker performs reconnaissance, lateral movement, and staged data theft from Finance/HR/Engineering shares before deploying ransomware for dual extortion leverage.

Backup Destruction Before Ransomware / Wiper. Attacker enumerates all backup infrastructure (VSS, Veeam, cloud vaults) during business hours, then systematically destroys every recovery layer before deploying a wiper.

Wiper Payload Disguised as Scheduled Maintenance. Destructive payload masquerading as a routine maintenance script is deployed during a legitimate change window to destroy data across multiple systems.

AiTM Phishing to SharePoint Mass Exfiltration. AiTM session capture followed by MFA device registration, inbox rule creation, email thread hijacking for lateral phishing, and mass SharePoint document exfiltration over HTTPS.

Device-Code Phishing to DCSync Domain Credential Dump. Device code phishing grants persistent token access; attacker pivots from M365 to on-premises AD via hybrid connector and performs DCSync to extract all domain hashes.

OAuth Consent Phishing to Slow-Drip Data Exfiltration. Malicious OAuth app established as persistent data pipeline, slowly exfiltrating mailbox and OneDrive content in low-volume batches across weeks.

Poisoned CI Pipeline to VM Snapshot Exfiltration. Malicious CI workflow dumps cloud credentials, uses them to create VM disk snapshots, and exports them to an attacker-controlled bucket for offline analysis.

Contractor VPN Compromise to eDiscovery Mass Export. Compromised contractor VPN account used for network recon, lateral movement, AD CS privilege escalation, hybrid identity manipulation, and multi-day eDiscovery mass export.

USB Malware Propagation. Malware auto-executes from an inserted USB device, replicates to connected drives, establishes C2, and spreads across the network through file share enumeration.

Mass Download Before Resignation. Resigning employee systematically downloads sensitive data from SharePoint, OneDrive, and network shares across multiple days using a personal sync app before departure.

Cloud Storage Sync Exfiltration. Employee installs personal cloud sync app and progressively synchronises corporate SharePoint, OneDrive, and network share content to personal storage before sharing externally.

E SOC Tool Catalog

Legion-Bench exposes seven SOC tool categories to investigated agents. Each category is backed by a named real-platform analogue; tool names visible to the agent follow the pattern

<prefix>_<function>. Each entry lists required parameters (*req.*) and optional parameters (*opt.*) separately.

SIEM — Splunk Enterprise Security (splunk_*)

Data scope: login, email, file, admin, app, process, MFA, device, print, and network events; employees, devices, and subnets reference tables.

splunk_run_query *Req.* query; *opt.* limit, time_start, time_end.
Execute an arbitrary SQL SELECT on any event or reference table. Supports JOINs across all ten event tables and the three reference tables.

splunk_search_app_events *Opt.* employee_id, app, action, resource_type, resource_name, success, time_start, time_end, limit.
Search application activity events (Slack, GitHub, Salesforce, Jira, Okta, . . .).

splunk_search_dashboard *Opt.* employee_id, device_id, time_start, time_end.
Pre-built activity dashboard for a user or device: comprehensive summary across all event types.

EDR — CrowdStrike Falcon (cs_*)

Data scope: process, device, and network events; login events; employee and device tables.

cs_get_process_tree *Opt.* device_id, employee_id, process_name, time_start, time_end.
Parent-child process execution tree for a device or user.

cs_search_process_by_hash *Req.* hash.
Find all executions of a binary by SHA-256 hash, showing which hosts ran it and when.

cs_search_process_by_command *Req.* command_pattern; *opt.* time_start, time_end.
Find processes by command-line substring — useful for detecting encoded payloads or suspicious arguments.

cs_get_host_timeline *Req.* device_id; *opt.* time_start, time_end, limit.
Chronological endpoint timeline: processes, USB connections, and software installs.

cs_get_device_events *Opt.* employee_id, device_id, action, time_start, time_end.
USB connections, Bluetooth events, and software installs/uninstalls. action: usb_connected, usb_disconnected, software_install, software_uninstall, bluetooth_connect, bluetooth_disconnect.

cs_detect_suspicious_processes *Opt.* suspicious_names, time_start, time_end.
Detect known LOLBins and hacking tools. A custom name list overrides the built-in default.

cs_get_network_events *Opt.* source_ip, destination_ip, action, time_start, time_end, limit.
Raw network events (firewall logs, connection records).

cs_search_network_events *Opt.* ip, url, time_start, time_end, limit.
Search network events by IP or domain pattern, matching both source and destination fields.

Identity — Microsoft Entra ID (entra_*)

Data scope: login events, MFA events, admin actions, employee and device records, group memberships.

entra_lookup_user *Req.* user_ref (ID, email, or display name).
Resolve a user to a full profile including authorisations and linked accounts.

entra_sign_in_logs *Opt.* employee_id, email, success, time_start, time_end, limit.
Authentication events with IP address, MFA status, geography, and accessed applications.

entra_mfa_activity *Opt.* employee_id, action, time_start, time_end.
MFA push notifications, approvals/denials, and device registrations/removals. action: push_sent,

`push_approved`, `push_denied`, `device_registered`, `device_removed`, `code_entered`, `code_failed`.

`entra_get_user_groups` *Req.* `user_ref`.
All security and distribution groups a user belongs to, with each group's authorisations.

`entra_get_group_members` *Req.* `group_ref`.
All members of a security or distribution group.

`entra_user_audit_log` *Opt.* `employee_id`, `action`, `time_start`, `time_end`, `limit`.
Audit trail of account changes: group modifications, role assignments, password resets.

`entra_user_access_review` *Req.* `user_ref`.
Comprehensive access review: all groups, authorisations, devices, and recent admin changes.

`entra_risky_users` *Opt.* `time_start`, `time_end`.
Users with risky sign-in patterns: failed logins, MFA denials, and impossible travel indicators.

Email Security — Microsoft Defender for Office 365 (`defender_*`)

Data scope: email events, employee records, mailboxes and distribution lists.

`defender_search_emails` *Opt.* `sender`, `subject_contains`, `recipient`, `ip`, `url`, `filename`, `time_start`, `time_end`, `limit`.
Search the message trace by any combination of indicators; filters combine with AND logic.

`defender_get_email_attachments` *Opt.* `sender`, `filename_contains`, `file_type`, `time_start`, `time_end`.
Find emails carrying specific attachments, filtered by sender, filename substring, or extension.

`defender_get_sender_summary` *Req.* `sender`.
Profile a sender: message count, recipients reached, subject distribution, and attachment statistics.

`defender_find_phishing_indicators` *Opt.* `sender_domain`, `time_start`, `time_end`.
Identify external emails with phishing signals: embedded URLs, executable attachments, or urgency subjects.

DLP / IRM — Microsoft Purview (`purview_*`)

Data scope: file events, print events, email events, employee records.

`purview_get_dlp_alerts` *Opt.* `employee_id`, `policy_name`, `time_start`, `time_end`, `limit`.
DLP policy violation alerts: sensitive-data sharing, unauthorised transfers, and classification breaches.

`purview_get_irm_alerts` *Opt.* `employee_id`, `policy_name`, `time_start`, `time_end`, `limit`.
Insider Risk Management alerts: bulk downloads, unusual file-access patterns, print anomalies, and exfiltration indicators.

Threat Intelligence — VirusTotal / AbuseIPDB (`ti_*`)

Data scope: attack ground-truth IOC feeds, process events, email events, login events.

`ti_lookup_domain` *Req.* `domain`.
Check a domain against threat feeds. Returns verdict (malicious / unknown) and associated campaigns.

`ti_lookup_ip` *Req.* `ip_address`.
Check an IP address. Returns verdict and associated attack campaigns.

`ti_lookup_hash` *Req.* `file_hash`.
Check a SHA-256 (or other) hash. Returns verdict, first-seen date, and affected host count.

`ti_lookup_url` *Req.* `url`.
Check a URL. Returns verdict, associated attacks, and email delivery count.

`ti_lookup_email_address` *Req.* `email`.
Check an email address: internal flag, known attack associations, and total outbound message count.

`ti_lookup_filename` *Req.* `filename`.
Check a filename against known malicious names in attack campaigns, process events, and email attachments.

`ti_get_known_iocs` *Opt.* `ioc_type` (`domain`, `ip`, `hash`, `url`, `email`, `filename`).
List all IOCs from threat feeds, optionally filtered by type.

CNAPP — Wiz (`cnapp_*`)

Data scope: cloud instances, containers, vulnerabilities, misconfigurations, threats, and API audit logs (AWS CloudTrail, Azure Activity Log, GCP Audit Log).

`cnapp_search_resource` *Opt.* `resource_id`, `identity`, `provider`, `resource_type`.
Discover cloud resources or IAM identities with network configuration, permissions, and findings.

`cnapp_search_vulnerabilities` *Opt.* `resource_id`, `cve_id`, `severity`, `provider`, `limit`.
CWPP vulnerability findings by CVE, severity, or resource. `severity`: `critical`, `high`, `medium`, `low`.

`cnapp_search_misconfigurations` *Opt.* `resource_id`, `category`, `severity`, `provider`, `limit`.
CSPM findings: open security groups, public buckets, missing encryption, logging gaps, and more. `category`: `networking`, `encryption`, `access_control`, `logging`.

`cnapp_get_threat_details` *Opt.* `resource_id`, `identity`, `threat_type`, `severity`, `limit`.
Cloud threat detections: unauthorized access, cryptomining, data exfiltration, and related attacks.

`cnapp_search_cloud_events` *Opt.* `instance_id`, `identity`, `event_name`, `event_source`, `event_category`, `provider`, `source_ip`, `response_status`, `read_only`, `time_start`, `time_end`, `limit`.
Query cloud API audit logs across AWS, Azure, and GCP. `event_category`: `management`, `data`, `network`, `auth`, `monitoring`. `response_status`: `Success`, `Failed`, `AccessDenied`.

`cnapp_get_cloud_identity_activity` *Req.* `identity`; *opt.* `time_start`, `time_end`, `limit`.
All cloud API calls made by a specific IAM identity — useful for investigating compromised service accounts.

`cnapp_get_cloud_event_summary` *Opt.* `instance_id`, `identity`, `provider`, `time_start`, `time_end`.
Cloud API calls aggregated by event name with counts and time ranges, enabling anomaly detection.

F Agent and Evaluator Prompts

All agents share a common **Report Format** template and **Employee-ID note** injected into their respective system prompts. These are shown first, followed by the architecture-specific prompts and finally the LLM judge prompt used for Findings Recall evaluation.

Shared: Report Format (injected into all agent system prompts)

```
**Executive Summary**: One-paragraph overview of what happened,
the severity, and immediate risk.

**Findings** (focus on the essential elements that define this attack
- be specific and include evidence):
- The specific attack technique or vector used (what makes this attack
  distinctive)
- Key attacker actions that confirm the attack (e.g., impossible travel,
  credential replay, privilege escalation)
- Persistence or defense evasion mechanisms (e.g., MFA registration,
  inbox rules, scheduled tasks, service principals)
- Ultimate impact - what data, systems, or access was compromised
- Any lateral movement to other accounts, hosts, or cloud resources

Prioritize the core narrative of the attack over exhaustive enumeration
```

```
of every step. Focus on the critical evidence that proves the attack
happened, identifies the technique, and defines its scope and impact.

**Indicators of Compromise (IOCs)** -- list each IOC belonging to the
attacker on its own line. The different types of IOCs are: IPs, domains,
URLs, emails, hashes, and filenames. Just list the IOCs, no other text.

**Severity Assessment**: Your assessment of the incident severity.
```

Employee-ID note (appended to every system prompt): "Employee IDs are different from their email addresses. Almost all functions require employee IDs and will not work with email addresses. The first step needs to be to get the employee ID from the email address."

Direct Agent

```
You are an expert SOC (Security Operations Center) analyst conducting
a security investigation.

## Your Task

You have been given a security alert to investigate. Use the available
tools to gather evidence, analyze the situation, and produce a
comprehensive investigation report.

## Tool Usage

- You have access to SOC tools (SIEM, EDR, identity, email gateway,
  DLP, threat intel, CNAPP).
- Each tool call returns structured data (lists of events, user
  records, etc.).
- Call multiple tools per turn when the queries are independent.

## Final Report

When you have gathered enough evidence, provide your final investigation
report with this structure:

[REPORT FORMAT]

Do NOT call any tools when providing your final report - just output
the report text.
```

ReAct Agent

```
You are an expert SOC (Security Operations Center) analyst conducting
a security investigation. You follow a strict Thought-Action-Observation
loop.

## Your Methodology

On EVERY turn, you MUST follow this exact pattern:

**Thought**: Reason about the current state of the investigation.
What do you know so far? What hypotheses are you testing? What
information do you still need?

**Action**: Based on your reasoning, call one or more tools to gather
evidence. Call multiple tools per turn when the queries are independent.

The system will return **Observation** results from your tool calls,
and then you repeat the cycle with a new Thought.

## Important Rules
```

```
1. ALWAYS start your response with "**Thought**:" followed by your
   reasoning.
2. After your thought, make your tool calls (the Action).
3. Continue this Thought-Action-Observation cycle until you have
   enough evidence.
4. When ready to conclude, output one final "**Thought**:" summarizing
   your findings, then provide your report WITHOUT any tool calls.

[REPORT FORMAT]
```

SPA (See–Plan–Act) Agent

```
You are an expert SOC analyst. You follow a strict Plan-then-Act
methodology.

## Your Methodology

### Planning Phase
- Analyze the alert, indicators, and any evidence gathered so far.
- Create a structured investigation plan listing the specific queries
  you will run and why.
- Do NOT attempt any tool calls during planning - just output your
  plan as text.

### Execution Phase
- Execute your plan by calling the available tools.
- Call multiple tools per turn when the queries are independent.
- If your findings reveal that your plan needs revision (e.g.,
  unexpected results, new leads, dead ends), call the ‘request_replan‘
  tool to return to the planning phase.
- When you have gathered enough evidence, provide your final report
  without any tool calls.

[REPORT FORMAT]

--- [Execute prompt, injected after plan is produced] ---

Good. Now execute your investigation plan using the available tools.
Call multiple tools per turn when the queries are independent. If at
any point your findings require a change in investigation direction,
call the ‘request_replan‘ tool to create a revised plan. When you
have gathered enough evidence, provide your final report without any
tool calls.

--- [Replan prompt, injected on ‘request_replan‘ call] ---

You requested to revise your investigation plan. Reason: {reason}

Based on everything you’ve learned so far, create a new investigation
plan. Consider:
- What have you confirmed so far?
- What questions remain unanswered?
- What new leads or directions have emerged?
- What specific queries will you run next and why?

Output only your revised plan - do not call any tools.
```

Reflexion Agent

Pass 1 Investigator (same as Direct; produces draft report).

Critic system prompt.

```
You are a senior SOC analyst reviewing a junior analyst’s investigation
```

```
report. Your job is to identify gaps, errors, and areas that need
deeper investigation.

Be specific and actionable in your critique. For each gap, explain
exactly what additional queries or analysis should be performed.
```

Critic user prompt.

```
## Original Alert
{alert_summary}

## Draft Investigation Report
{draft_report}

## Review Instructions

Critically review this investigation report. Focus on whether it
captures the essential elements of the attack - not every minor detail,
but the core findings that matter. Identify:

1. **Attack technique unclear**: Is the specific attack vector clearly
   identified with evidence?
2. **Missing key attacker actions**: Were critical pivot points
   (e.g., credential replay, privilege escalation, persistence setup)
   investigated and confirmed?
3. **Impact not established**: Is it clear what data, systems, or
   access was ultimately compromised?
4. **Unverified claims**: What conclusions lack supporting evidence
   from tool queries?
5. **Missing IOC categories**: Were all IOC types checked (IPs,
   domains, hashes, emails)?

Focus your critique on gaps in the core attack narrative - the
technique, the key indicators, persistence mechanisms, and impact.
Do not flag missing details that are supplementary (e.g., every
intermediate recon step or every file accessed).

For each gap, provide a specific recommendation for what the analyst
should investigate next.
```

Pass 2 system prompt.

```
You are an expert SOC analyst conducting a follow-up investigation to
address gaps identified in a peer review of your initial findings.

## Your Task

A senior analyst has reviewed your draft report and identified gaps.
Use the available tools to address each gap, then produce an improved
final report that incorporates both your original findings and the
new evidence.

[REPORT FORMAT]
```

Pass 2 user prompt.

```
## Your Draft Report
{draft_report}

## Senior Analyst Critique
{critique}

Address the gaps identified above. Use the available tools to gather
additional evidence, then produce an improved final report.
```

Multi-Agent Architecture

Coordinator triage system prompt.

```
You are a senior SOC coordinator. Your role is to triage security
alerts and assign investigation tasks to domain specialists.

You do NOT have access to any tools. Your job is to analyze the alert
and create a structured task assignment for each specialist.
```

Coordinator triage user prompt.

```
## Alert: {alert_title}

**Severity**: {severity}
**Source**: {source}

### Description
{description}

### Initial Indicators
{indicators}

### Available Specialists
{specialists}

## Instructions

Analyze this alert and create specific investigation tasks for each
available specialist. For each specialist, provide:
1. What they should investigate
2. Specific queries or checks to perform
3. What evidence to look for
```

Specialist system prompt (instantiated per domain).

```
You are a specialist SOC analyst in the **{role}** domain. You are
part of a team investigating a security alert. Your coordinator has
assigned you specific tasks.

## Your Scope

You only have access to tools in your domain. Focus on your assigned
tasks and produce a concise findings report for the coordinator.

## Output

When done, provide a structured summary of your findings, focusing on:
- The core attack technique or attacker actions you identified
  (with evidence)
- Any persistence or defense evasion mechanisms discovered
- IOCs found (IPs, domains, hashes, emails, URLs)
- Risk assessment for your domain
- Any leads that other specialists should follow up on

Focus on the critical evidence that defines the attack - not every
minor event, but the key findings that prove what happened and its
impact.
```

Coordinator synthesis system prompt.

```
You are a senior SOC coordinator synthesizing investigation findings
from your specialist team into a final, comprehensive investigation
report.
```

```
You do NOT have access to any tools. Synthesize all specialist
findings into a single report.

[REPORT FORMAT]
```

Coordinator synthesis user prompt.

```
## Original Alert
{alert_summary}

## Specialist Reports
{specialist_reports}

## Instructions

Synthesize all specialist findings into a single comprehensive
investigation report. Resolve any contradictions, identify patterns
across domains, and provide a unified timeline and assessment.

Focus the report on the essential attack narrative: the specific
technique used, the key attacker actions that confirm the attack,
persistence/evasion mechanisms, and the ultimate impact. Prioritize
critical evidence over exhaustive enumeration of every step.
```

Findings Recall Evaluator (LLM Judge)

The judge is called with `temperature=0.0` using `gpt-4o-mini` and is instructed to return strict JSON (no markdown fences) containing (found / not found, supporting quote, confidence).

System prompt.

```
You are a strict evaluation judge for a SOC (Security Operations Center)
investigation benchmark.

You will be given:
1. An investigation report written by an AI agent.
2. A list of expected findings that the agent should have identified.

For each expected finding, determine whether the report contains
SPECIFIC, CONCRETE information that substantively demonstrates the
agent discovered this finding through its investigation. Apply these
strict rules:

MATCHING RULES:
- The report must show the agent actually IDENTIFIED and INVESTIGATED
  the finding, not merely restated the alert description or ticket
  information.
- Semantic equivalence is acceptable - the match does NOT need to be
  verbatim. For example, "bulk download of files" matches "mass file
  download".
- Expected findings describe the essential, high-level elements of the
  attack (technique, key actions, persistence, impact). Match
  generously on scope - if the expected finding is broad (e.g., "data
  exfiltrated over C2"), the report satisfies it by showing ANY
  specific evidence of that activity (e.g., mentioning the C2 IP and
  outbound transfer).
- A finding is FOUND only if the report provides specific evidence or
  details about it (e.g., specific IPs, timestamps, user actions, tool
  outputs).
- A finding is NOT FOUND if:
  * The report only vaguely alludes to it without specifics
  * The report merely repeats information from the initial alert/ticket
    without adding investigation results
  * The information is mentioned in a recommendation section but was
```

```
    never actually confirmed
  * The report speculates about it without evidence from tool queries

Return a JSON object with a single key "results" containing an array
with one entry per expected finding, in the same order. Each entry
must have:
- "index": the 0-based index of the finding
- "found": true/false
- "evidence": a brief quote or paraphrase from the report that
  supports your decision (or "not found in report" if not found)
- "confidence": a float 0.0-1.0 indicating your confidence

Example output:
{"results": [{"index": 0, "found": true,
  "evidence": "Report states: Query returned 2847 file download events
  from SharePoint between March 10-12", "confidence": 0.95}]}

IMPORTANT: Return ONLY valid JSON, no markdown fences or extra text.
Be strict - when in doubt, mark as not found.
```

User prompt.

```
## Investigation Report

{report}

## Expected Findings

{numbered_list_of_expected_findings}
```

G Golden Workflow Baseline

The *Golden Workflow* is a deterministic playbook included in LEGION SECURITY BENCH as a reproducible upper-bound baseline. Unlike the five LLM-driven agents (Direct, ReAct, SPA, Reflexion, Multi-Agent), which choose every tool call dynamically, the Golden Workflow executes a fixed, pre-specified sequence of SOC tool calls derived from expert-authored playbooks, then issues a *single* LLM call to synthesise the collected evidence into a final report. Because the tool call sequence is fully determined by the alert type and the content of earlier results, two runs on the same alert and database always produce identical tool calls, making the baseline reproducible and free of sampling variance.

Architecture Overview

Execution proceeds in two stages:

1. **Deterministic execution.** The alert is routed to one of four typed workflows (Account-Takeover, Phishing, Malware, or DLP). Each workflow is a list of `WorkflowStep` objects. Every step specifies a tool name and a *builder function* that maps the current `ExecutionContext` — the mutable state accumulating all prior tool call results — to a list of argument dicts. Steps that fan out (e.g., one TI lookup per suspicious IP observed in sign-in logs) produce multiple parallel tool calls; steps whose builder returns an empty list are silently skipped. No LLM is involved in deciding which tool to call or what arguments to pass.
2. **Single LLM synthesis.** Once all steps complete, a single LLM call (using the same model as the evaluated agents) receives the full evidence corpus and produces the investigation report in the shared report format (§F).

The `ExecutionContext` provides typed extraction helpers (`collect_ips`, `collect_domains`, `collect_urls`, `collect_hashes`, `collect_external_senders`, `collect_filenames`) that parse prior tool results to derive the parameters for downstream steps, implementing the data-dependency graph of each playbook without any LLM reasoning.

Alert Routing

Alerts are routed deterministically by the `pick_golden_workflow` function, which maps the alert's `source` field to a workflow:

Alert Source	Workflow
`purview`	DLP
`crowdstrike`	Malware
`defender_o365`	Phishing
`entra_id`	AccountTakeover
`splunk_es`	AccountTakeover (default) or Malware (title prefix match for supply-chain alerts)

Routing achieves 100% alignment with the intended workflow on the 98 scenario tickets in our benchmark fixtures (verified against ground-truth attack types). A small number of structurally ambiguous alerts — such as a personal email exfiltration ticket fired by `defender_o365` — are intentionally routed by ticket framing rather than underlying attack type, mirroring real analyst triage practice.

AccountTakeover Workflow (13 Steps)

Designed for identity-compromise alerts from Entra ID or Splunk ES. Phases map to the pre-Verdict nodes of the AccountTakeover SOC playbook.

USER CONTEXT — `entra_lookup_user` Resolve the alerted email to a full user profile and authorisation set.

USER GROUPS — `entra_get_user_groups` Enumerate security group memberships to establish blast radius.

SIGN-IN LOGS — `entra_sign_in_logs` Retrieve authentication events in a $\pm$2-day window around the alert timestamp (up to 200 events).

AUDIT LOG — `entra_user_audit_log` Fetch the account-change audit trail: password resets, MFA modifications, group changes, and delegation rules.

MFA ACTIVITY — `entra_mfa_activity` Retrieve push notifications, approvals/denials, and device registration events for the same window.

RISK DETECTIONS — `entra_risky_users` Query risky sign-in patterns: impossible travel, anomalous failure bursts, and leaked credential indicators.

IP THREAT INTEL — `ti_lookup_ip` **(fan-out)** For each distinct external IP observed in sign-in logs, submit a threat-feed lookup. Multiple playbook nodes (IP_REP, IP_GEO, IP_VPN, IP_TI_FEED) collapse to a single call per IP.

IP ORG HISTORY — `splunk_run_query` Cross-reference suspicious IPs against the full login table to identify other accounts targeted from the same source addresses.

ADVERSARY HUNTING — `splunk_search_dashboard` Broad activity dashboard for the victim to surface anomalies not captured by prior targeted queries.

ENDPOINT DEVICE EVENTS — `cs_get_device_events` Check for USB insertions, Bluetooth connections, and software installs on the victim's enrolled device.

PROCESS TREE — `cs_get_process_tree` Inspect endpoint process execution for post-compromise tooling or persistence mechanisms.

NETWORK CORROBORATION — `cs_search_network_events` **(fan-out)** For each suspicious IP, query whether it communicated with the victim's endpoint.

PHISHING CORRELATION — `defender_search_emails` Search the mail gateway for phishing emails delivered to the victim before the anomalous sign-in, linking the potential initial access vector.

Phishing Workflow (19 Steps)

Designed for email-gateway alerts from Microsoft Defender for Office 365.

RECIPIENT CONTEXT — `entra_lookup_user` Resolve recipient identity and access profile.

DELIVERY STATUS — `defender_search_emails` Retrieve all emails delivered to the recipient in a $\pm$2-day window, extracting sender addresses, URLs, and attachment metadata.

SENDER PROFILE — `defender_get_sender_summary` **(fan-out)** Profile each external sender: message volume, recipient spread, and attachment statistics.

SENDER DOMAIN HISTORY — `defender_find_phishing_indicators` **(fan-out)** Query the 30-day phishing-indicator history for each external sender domain.

SENDER EMAIL TI — `ti_lookup_email_address` **(fan-out)** Threat-feed lookup on each external sender address.

SENDER DOMAIN TI — `ti_lookup_domain` **(fan-out)** Threat-feed lookup on the domain of each external sender.

URL TI — `ti_lookup_url` **(fan-out)** Threat-feed lookup on each URL extracted from delivered emails.

URL DOMAIN TI — `ti_lookup_domain` **(fan-out)** Threat-feed lookup on the hostname of each embedded URL, providing the URL_CATEGORY signal present in the playbook.

ATTACHMENT METADATA — `defender_get_email_attachments` **(fan-out)** Retrieve detailed attachment metadata per external sender.

ATTACHMENT HASH TI — `ti_lookup_hash` **(fan-out)** Threat-feed lookup on SHA-256 hashes of all retrieved attachments.

ATTACHMENT FILENAME TI — `ti_lookup_filename` **(fan-out)** Check attachment filenames against known malicious filename feeds.

CAMPAIGN SCOPE — `defender_search_emails` **(fan-out)** Search the last 7 days for all recipients of the same sender, scoping the phishing campaign.

SIGN-IN LOGS — `entra_sign_in_logs` Detect post-click credential submission: foreign IP login shortly after email delivery.

AUDIT LOG — `entra_user_audit_log` Inbox rules, MFA changes, and delegation modifications indicating post-compromise persistence.

MFA ACTIVITY — `entra_mfa_activity` MFA push history to detect fatigue attacks or unauthorised device enrolment.

POST-CLICK IP TI — `ti_lookup_ip` **(fan-out)** Threat-feed lookup on each IP observed in post-delivery sign-in logs.

ENDPOINT PROCESSES — `cs_get_process_tree` Process tree to detect payload execution following a malicious attachment open.

ENDPOINT DEVICE EVENTS — `cs_get_device_events` USB and device events on the victim endpoint.

USER ACTIVITY DASHBOARD — `splunk_search_dashboard` Comprehensive cross-source activity summary to surface any signals missed by the targeted steps.

Malware Workflow (14 Steps)

Designed for EDR-sourced alerts from CrowdStrike Falcon. The workflow pivots on endpoint telemetry, establishing the process footprint before enriching discovered artefacts with threat intelligence and correlating across identity, network, and email sources. Sandbox-based nodes (HASH_SANDBOX, URL_SANDBOX) and the CMD_ANALYZE node are skipped, as no detonation service is available and LLM calls during execution are explicitly excluded.

USER CONTEXT — `entra_lookup_user` Phase 1: directory profile of the affected user to establish identity and authorisation context.

USER SIGN-INS — `entra_sign_in_logs` Phase 1: recent authentication logs for host attribution and identification of foreign source IPs.

USER AUDIT — `entra_user_audit_log` Phase 1: post-compromise account changes (password resets, MFA modifications, new delegations).

ENDPOINT PROCESS TREE — `cs_get_process_tree` Phase 3: full parent-child process execution tree on the user's device across the alert window.

ENDPOINT DEVICE EVENTS — `cs_get_device_events` Phase 3: USB connections, software installs, and removable-media events on the endpoint.

LOLBIN SCAN — `cs_detect_suspicious_processes` Phase 3: sweep for known living-off-the-land binaries and offensive tools (`powershell`, `mshta`, `certutil`, `mimikatz`, `rubeus`, etc.).

HASH TI — `ti_lookup_hash` **(fan-out)** Phase 2: threat-feed lookup per distinct binary hash observed in process tree or device events. Collapses playbook nodes HASH_REP, HASH_INTEL, HASH_OSINT, and HASH_SIGNED into a single call per hash.

HASH PREVALENCE — `cs_search_process_by_hash` **(fan-out)** Phase 2: check whether the same hash has executed on other endpoints in the environment (HASH_ENV node).

IP THREAT INTEL — `ti_lookup_ip` **(fan-out)** Phase 2: threat-feed lookup per external IP extracted from process tree, device, or sign-in events (covers IP_REP, IP_ABUSE, IP_GEO).

NETWORK CORROBORATION — `cs_search_network_events` **(fan-out)** Phase 3: network telemetry per suspicious IP to detect C2 communication and lateral movement.

DOMAIN TI — `ti_lookup_domain` **(fan-out)** Phase 2: threat-feed lookup per distinct domain from emails or network events (covers URL_REP, URL_CATEGORY).

USER ACTIVITY DASHBOARD — `splunk_search_dashboard` Phase 3: SIEM activity dashboard across login, file, and application event types to surface anomalies not captured by targeted queries.

EMAIL TRAIL — `defender_search_emails` Phase 3: search the mail gateway for emails delivered to the victim that may have carried the initial malware payload.

FILENAME TI — `ti_lookup_filename` **(fan-out)** Phase 3: threat-feed lookup per attachment filename from email lures associated with the incident.

DLP Workflow (15 Steps)

Designed for data-loss prevention alerts from Microsoft Purview. The workflow begins with user context and a 90-day DLP/IRM history to establish whether the event is part of a pattern, then inspects all plausible exfiltration channels (file access, outbound email, print, cloud sharing, removable media) before enriching external destinations with threat intelligence. Nodes without a registry equivalent are skipped: trusted third-party GRC verification, OSINT-based destination reputation, file-content encryption analysis, and CASB cloud-sharing scope.

USER CONTEXT — `entra_lookup_user` Phase 2A: directory profile of the user triggering the DLP alert.

USER GROUPS — `entra_get_user_groups` Phase 2A: group memberships to determine authorised data scope and blast radius.

DLP HISTORY — `purview_get_dlp_alerts` Phase 2A: 90-day DLP alert history to detect repeat-offender patterns (Background Analytics node).

IRM ALERTS — `purview_get_irm_alerts` Phase 2A: Insider Risk Management signals over 90 days — bulk download indicators, leaver-risk flags, and anomalous access patterns.

USER ACCESS REVIEW — `entra_user_access_review` Phase 2A: comprehensive access review covering all groups, authorisations, devices, and recent admin changes.

FILE EVENTS — `splunk_run_query` Phase 2C: 7-day file-event timeline including downloads, uploads, copies, and shares, with sensitivity labels and file descriptions.

OUTBOUND EMAIL — `splunk_run_query` Phase 2B/2C: all external outbound emails sent by the user in the past 7 days, with attachment types and external recipients.

PRINT EVENTS — `splunk_run_query` Phase 2D: print activity for the user, covering document names, page counts, and printer identifiers.

SIGN-IN LOGS — `entra_sign_in_logs` Phase 2C: authentication and VPN events around the alert to assess whether access occurred from an anomalous location or device.

USER ACTIVITY DASHBOARD — `splunk_search_dashboard` Phase 2C: SIEM activity dashboard to surface cross-event-type anomalies.

ENDPOINT DEVICE EVENTS — `cs_get_device_events` Phase 2D: USB insertions and removable-media events on the user's enrolled device (USB whitelist check).

APP EVENTS — `splunk_search_app_events` Phase 2D: SharePoint, OneDrive, and collaboration-platform sharing and export actions over 7 days.

DOMAIN TI — `ti_lookup_domain` **(fan-out)** Phase 2B: threat-feed lookup per destination domain extracted from file and email events (flags personal email services and competitor domains).

IP TI — `ti_lookup_ip` **(fan-out)** Phase 2B: threat-feed lookup per external IP from sign-in or query results.

EXTERNAL RECIPIENT TI — `ti_lookup_email_address` **(fan-out)** Phase 2B: threat-feed lookup per external recipient address from outbound email, targeting personal or anomalous destination accounts.